
HIPAA

Plain-Language Rule and Audit Guide

Security, Privacy, and Breach Notification Rules

What every requirement means, why it exists, how to audit it, what evidence to collect, how to document it, and how to report it.

Coverage

Who and what is covered, and the required/addressable distinction.

The Security Rule in full: administrative, physical, technical, organizational, and documentation requirements.

The Privacy Rule: uses, disclosures, and individual rights.

The Breach Notification Rule, and enforcement and penalties.

Before You Use This Document

This is a companion guide, not a copy of the standard.

The HIPAA Rules at 45 CFR Parts 160 and 164 are United States federal regulation and are in the public domain, so unlike the ISO guides in this series there is no copyright constraint on the underlying material. This guide still describes each provision in original plain language rather than reproducing the regulatory text, because the point is to make the requirements usable rather than to restate them.

Read the regulation itself for anything consequential. This guide is not legal advice. HIPAA compliance frequently turns on facts, on state law that may be more stringent and is not preempted, and on Office for Civil Rights guidance and enforcement practice that continues to develop. Where this guide and the regulation appear to differ, the regulation governs.

Two areas move and should be checked against the current position: the Security Rule has been the subject of proposed rulemaking that would change the required and addressable structure this guide describes, and reproductive health privacy provisions have been subject to litigation. Confirm both before relying on this guide alone. Note also that this guide covers Parts 160 and 164; the Part 162 transaction and code set standards are outside its scope.

What this guide does

It takes each obligation in the Regulation and answers six questions about it, in the same order every time:

1. **What the obligation requires.** The requirement in ordinary language, with no assumed background.
2. **Why it exists.** The failure it is there to prevent. Auditors who understand intent write better findings than auditors who only know the wording.
3. **How to audit it.** Specific test steps, in the order you would actually perform them.
4. **Evidence to collect.** Named artifacts. Not “documentation” but the actual thing to request.
5. **How to document it.** What belongs in the workpaper so a reviewer can follow your reasoning without re-performing your work.
6. **Executive summary treatment.** Suggested language if the item fails or rates high risk, written for an audience that does not read control numbers.

On vocabulary

Technical terms are defined the first time they appear, shown like [this](#), and collected in the glossary. If you hit a term that is not defined, that is a defect in this document; note it and it will be fixed in the next revision.

Navigating this document

Each part opens with a quick-reference table. Every reference number and title in those tables is a live link to the full entry, so the tables work as a jump menu rather than just a contents list. Entries also appear in the PDF bookmark panel, and the index at the back links back into the text.

Link colour carries meaning. Here it marks one thing only: whether a Security Rule standard contains *addressable* implementation specifications.

Orange, marked ADDR

A Security Rule standard containing one or more addressable implementation specifications. Each entry states, specification by specification, which are Required and which are Addressable.

Blue

Everything else: required specifications, standards with no specifications beneath them, every Privacy Rule provision, every Breach Notification provision, and the enforcement articles.

This inverts the convention used elsewhere in the series, deliberately. Blue here means *no flexibility at all*. Orange marks the small population where flexibility exists, and that population is worth finding because it is where the most common Security Rule finding lives.

Addressable does not mean optional. It means the entity must assess whether the specification is reasonable and appropriate for its circumstances, and then either implement it, or document why not *and* implement an equivalent alternative measure where reasonable and appropriate. An addressable specification that is neither implemented nor documented is a violation, not an exercise of discretion. Of the forty-nine entries in this guide, nine standards are orange; working through their specifications and recording each as implemented, alternative-implemented-with-documentation, or neither, is the single most efficient way to establish Security Rule posture.

One further note on why the colouring works this way. The companion GDPR guide colours entries by administrative fine tier, because Article 83 attaches tiers to specific articles. HIPAA's four-tier civil money penalty scheme does not work like that: the tiers key off *culpability*, meaning what the entity knew and what it did about it, rather than off which provision was breached. The same underlying failure can sit in any tier. That is addressed in the enforcement chapter rather than in the colour coding, and it has a practical consequence worth carrying through the whole assessment: a deficiency the organization already knew about and left open is materially worse than an undiscovered one.

The marker letters are printed as well as coloured, so the distinction survives greyscale printing and does not depend on colour vision. The required and addressable status of each specification is stated in the regulation rather than being a judgment of this guide; the classification is held in a single file in the source and can be re-scoped without touching any content.

One entry, one page

Every clause and control begins at the top of a fresh page and is complete before the next one starts. This wastes some paper and makes the document longer than it needs to be. It also means you can print a single control and hand it to the person who owns it, which is what these documents actually get used for.

How this guide is organized

The first chapter covers the foundational determinations: who is a covered entity or business associate, what counts as PHI and ePHI, de-identification, minimum necessary, and the required-versus-addressable structure. Get these wrong and everything downstream is scoped incorrectly.

The next four chapters cover the Security Rule in full, following its own structure: administrative, physical, technical, then organizational and documentation requirements. Implementation specifications are folded into their parent standard rather than treated separately, which keeps entries to roughly one page and matches how an assessor actually works.

Two chapters then cover the Privacy Rule, split between uses and disclosures and individual rights. The final two cover the Breach Notification Rule and the enforcement and penalty provisions of Part 160.

Five things that catch people out

Addressable is not optional. It is the most misread term in HIPAA. An addressable specification that is neither implemented nor supported by a documented determination is a violation. Build the list early: every addressable specification, marked implemented, alternative-implemented-with-documentation, or neither. The third column is the finding.

The risk analysis is the foundation and it is usually incomplete. Test its scope against the full ePHI inventory rather than reading its contents. Partial coverage is the characteristic failure, it is the most frequently cited deficiency in enforcement actions, and a risk analysis that omits systems cannot justify any addressable determination about them.

The Security Rule covers ePHI; the Privacy Rule covers PHI in any form. A security-led programme will map electronic systems thoroughly and leave paper records, imaging, and oral communication entirely unaddressed. Ask where PHI exists in non-electronic form and what protects it.

Breach discovery is constructive, not actual. The 60-day clock starts when the entity knew or by reasonable diligence would have known, including through any workforce member, not when the investigation concludes or when management is briefed. Establish that date independently. And note the burden of proof sits with the entity: it must demonstrate either that it notified or that no breach occurred.

Knowledge changes the penalty tier. HIPAA penalties key off culpability. A deficiency identified in a prior assessment and left unremediated establishes organizational knowledge, which can convert a lowest-tier position into wilful neglect and simultaneously forfeit the 30-day correction defense. When findings repeat, say so explicitly.

Three definitions you need before anything else

Required and Addressable

The two kinds of implementation specification. Required means implement as stated, with no alternative. Addressable means assess, then either implement, or document why not and implement an equivalent alternative where reasonable and appropriate. Standards themselves are always mandatory, including those with no specifications beneath them.

Covered entity and business associate

A covered entity is a health plan, clearinghouse, or provider transmitting health information electronically for a covered transaction. A business associate creates, receives, maintains, or transmits PHI on its behalf,

and has been directly liable since the Omnibus Rule. Status follows function, not contract: an entity can be a business associate without having signed anything, and is liable regardless.

Unsecured PHI

PHI not rendered unusable, unreadable, or indecipherable through a technology or methodology specified by the Secretary. Breach notification attaches only to *unsecured* PHI, which is why encryption matters well beyond the Security Rule: properly encrypted data that is lost or stolen generally does not trigger notification at all.

How to read the executive summary sections

Every entry ends with suggested reporting language. It is deliberately written to avoid three habits that get security findings ignored: control numbers in the first sentence, adjectives about maturity, and recommendations that amount to “do it better.” Each one names a specific consequence and, where possible, attaches a number. Adapt the wording; keep the structure.

Contents

Before You Use This Document	ii
1 Foundations: Who and What Is Covered	1
Covered entities Covered entities: who the Rules apply to directly	2
Business associates Business associates and subcontractors	3
PHI and ePHI Protected health information and its electronic form	4
De-identification De-identification: Safe Harbor and Expert Determination	5
Minimum necessary The minimum necessary standard	6
Required and Addressable Required and addressable specifications (45 CFR 164.306)	7
2 Security Rule: Administrative Safeguards	8
164.308(a)(1) Security management process	9
164.308(a)(2) Assigned security responsibility	10
164.308(a)(3) Workforce security	11
164.308(a)(4) Information access management	12
164.308(a)(5) Security awareness and training	13
164.308(a)(6) Security incident procedures	14
164.308(a)(7) Contingency plan	15
164.308(a)(8) Evaluation	16
164.308(b) Business associate contracts and other arrangements	17
3 Security Rule: Physical Safeguards	18
164.310(a) Facility access controls	19
164.310(b) Workstation use	20
164.310(c) Workstation security	21
164.310(d) Device and media controls	22
4 Security Rule: Technical Safeguards	23
164.312(a) Access control	24
164.312(b) Audit controls	25
164.312(c) Integrity	26
164.312(d) Person or entity authentication	27
164.312(e) Transmission security	28
5 Security Rule: Organizational and Documentation Requirements	29
164.314(a) Business associate contracts or other arrangements	30
164.314(b) Requirements for group health plans	31
164.316 Policies, procedures, and documentation requirements	32
6 Privacy Rule: Uses and Disclosures	33
164.502 Uses and disclosures of PHI: general rules	34
164.504 Organizational requirements: BAs, hybrid entities, and organized arrangements . .	35

164.506	Treatment, payment, and health care operations	36
164.508	Uses and disclosures for which an authorization is required	37
164.510	Uses and disclosures requiring an opportunity to agree or object	38
164.512	Disclosures not requiring authorization or an opportunity to object	39
164.514(d)-(h)	Minimum necessary implementation and other requirements	40
7	Privacy Rule: Individual Rights and Administration	41
164.520	Notice of privacy practices	42
164.522	Right to request privacy protection for PHI	43
164.524	Right of access	44
164.526	Right to amend	45
164.528	Right to an accounting of disclosures	46
164.530	Administrative requirements of the Privacy Rule	47
8	Breach Notification Rule	48
164.402	Definition of breach and the risk assessment	49
164.404	Notification to individuals	50
164.406	Notification to the media	51
164.408	Notification to the Secretary	52
164.410	Notification by a business associate	53
164.412-414	Law enforcement delay, administrative requirements, and burden of proof . . .	54
9	Enforcement, Culpability, and Penalties	55
160.401-402	Basis for a civil money penalty and culpability categories	56
160.404-408	Penalty amounts and the factors considered	57
160.410	Affirmative defenses and the correction opportunity	58
	Glossary	59
	Index of Terms and Concepts	62

CHAPTER 1

Foundations: Who and What Is Covered

Six determinations that scope everything else. Whether you are a covered entity or a business associate, what counts as PHI and ePHI, what de-identification actually requires, what minimum necessary limits, and the required-versus-addressable structure that governs the entire Security Rule.

Get these wrong and the rest is scoped incorrectly. Two carry the most weight. The Security Rule applies only to ePHI while the Privacy Rule applies to PHI in any form, so a security-led programme will map electronic systems thoroughly and leave paper records, imaging, and oral communication entirely unaddressed. And addressable does not mean optional: it means assess, then either implement or document why not and implement an equivalent alternative.

An addressable specification that is neither implemented nor documented is a violation, and it is the single most common Security Rule finding. Build that list early.

Quick reference: foundations

Navigation: every reference and title below links to its full entry. Links shown in **orange** with a **CYB** or **AI** marker denote controls whose subject matter is specifically cybersecurity (CYB) or that are direct attachment points for AI system governance (AI). All others are **blue**.

Ref	Title	Primary evidence
Covered entities	Covered entities: who the Rules apply to directly	Covered entity status determination
Business associates	Business associates and subcontractors	Business associate inventory compiled independently
PHI and ePHI	Protected health information and its electronic form	PHI inventory across all media
De-identification	De-identification: Safe Harbor and Expert Determination	De-identification method per dataset
Minimum necessary	The minimum necessary standard	Role-based access definitions with PHI categories
Required and Addressable	Required and addressable specifications (45 CFR 164.306)	Addressable specification assessments with reasoning

Covered entities Covered entities: who the Rules apply to directly

WHAT THE PROVISION REQUIRES

A covered entity is a health plan, a health care clearinghouse, or a health care provider who transmits any health information in electronic form in connection with a transaction covered by the transaction standards. The provider limb turns on that electronic transmission: a provider who never conducts a covered transaction electronically is not a covered entity, however much health information it holds. Related concepts include the hybrid entity, where a single legal entity performs both covered and non-covered functions and designates its health care components, and the affiliated covered entity, where legally separate entities under common ownership or control designate themselves as a single covered entity.

WHY IT EXISTS

Status determines whether the Rules apply at all, and the common errors run in both directions. Organizations holding substantial health information assume they are covered when they are not, and organizations conducting a single covered transaction electronically discover they are covered when they believed otherwise. The hybrid entity designation is the mechanism that limits the Rules to the relevant part of a larger organization, and it must be made and documented rather than assumed.

HOW TO AUDIT IT

1. Establish the basis of covered entity status: plan, clearinghouse, or provider conducting covered transactions electronically.
2. Where hybrid entity status is claimed, verify the designation is documented and the health care components identified.
3. Check any affiliated covered entity designation is documented and the entities are under common ownership or control.
4. Confirm the scope of what is treated as covered matches the designation.

EVIDENCE TO COLLECT

- Covered entity status determination
- Hybrid entity designation with health care components identified
- Affiliated covered entity designation where applicable

HOW TO DOCUMENT IT

Record the basis for covered entity status and, for hybrid entities, whether the designation is documented. An undocumented hybrid designation means the Rules apply to the whole legal entity, which is a materially larger scope than the organization is likely operating to.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the organization operates as a hybrid entity without a documented designation of its health care components, so the Rules apply across the entire legal entity rather than the narrower scope it has been applying them to.

Business associates Business associates and subcontractors

WHAT THE PROVISION REQUIRES

A business associate is a person or entity that creates, receives, maintains, or transmits protected health information on behalf of a covered entity to perform a function or activity regulated by the Rules, or provides specified services involving disclosure of PHI. Since the HITECH Act and the Omnibus Rule, business associates are directly liable for compliance with the Security Rule and with specified Privacy Rule provisions, and a subcontractor that creates, receives, maintains, or transmits PHI on behalf of a business associate is itself a business associate. The conduit exception is narrow, covering entities that merely transport information without accessing it other than randomly or infrequently.

WHY IT EXISTS

Status follows function rather than contract, so an entity can be a business associate without having signed an agreement, and it is then directly liable regardless. The subcontractor chain matters because liability and contractual obligations flow all the way down, and organizations frequently lose visibility past the first tier. The conduit exception is routinely over-claimed by service providers that do in fact have access to PHI.

HOW TO AUDIT IT

1. Compile the actual population of entities handling PHI, independently of the executed agreement list.
2. Test conduit exception claims against actual access to PHI, since storage providers with access are not conduits.
3. Trace the subcontractor chain beyond the first tier and confirm agreements flow down.
4. Check whether cloud and software vendors handling PHI are recognised as business associates.

EVIDENCE TO COLLECT

- Business associate inventory compiled independently
- Executed agreements for comparison
- Subcontractor chain mapping
- Conduit exception analyses

HOW TO DOCUMENT IT

Compile the population from procurement, network, and data flow evidence rather than from the agreement register, since the entities missing from the register are precisely the finding.

EXECUTIVE SUMMARY TREATMENT

Suggested language: a stated number of vendors with access to protected health information have no business associate agreement in place, including cloud providers treated as conduits despite having access to the data they store.

PHI and ePHI Protected health information and its electronic form

WHAT THE PROVISION REQUIRES

Protected health information is individually identifiable health information transmitted or maintained in any form or medium, held or transmitted by a covered entity or business associate, with exclusions for education records covered by FERPA, certain student treatment records, and employment records held in the entity's role as employer. Electronic protected health information is PHI transmitted by or maintained in electronic media. Individually identifiable health information relates to health, health care provision, or payment, and either identifies the individual or provides a reasonable basis to believe it can be used to identify them.

WHY IT EXISTS

The Security Rule applies only to ePHI while the Privacy Rule applies to PHI in any form, including paper and oral communication, and conflating the two leaves paper records and conversations unprotected. The employment records exclusion is frequently misread: information does not lose protection because it concerns an employee, only where the entity holds it in its capacity as employer rather than as a covered entity.

HOW TO AUDIT IT

1. Establish where PHI resides in all forms, including paper, imaging, voice recordings, and unstructured stores.
2. Verify the Privacy Rule is applied to non-electronic PHI, not only to systems.
3. Test the employment records exclusion where claimed, checking the capacity in which the information is held.
4. Confirm identifiability is assessed against the reasonable basis standard rather than only direct identifiers.

EVIDENCE TO COLLECT

- PHI inventory across all media
- ePHI systems inventory
- Exclusion determinations with reasoning

HOW TO DOCUMENT IT

Record whether the organization's PHI inventory covers non-electronic forms, since a security-led programme frequently maps ePHI thoroughly and leaves paper and oral PHI entirely unaddressed.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the organization's inventory covers electronic systems only, so protected health information held in paper records and imaging is subject to no documented safeguards despite falling squarely within the Privacy Rule.

De-identification De-identification: Safe Harbor and Expert Determination

WHAT THE PROVISION REQUIRES

Health information that has been de-identified in accordance with the Rule is not protected health information and its use and disclosure are unrestricted. Two methods are available. Safe Harbor requires removal of eighteen specified identifier categories relating to the individual and to relatives, employers, and household members, and requires that the entity have no actual knowledge that the remaining information could identify the individual. Expert Determination requires a person with appropriate knowledge and experience applying generally accepted statistical and scientific principles to determine the risk is very small, with the methods and results documented.

WHY IT EXISTS

De-identification is the mechanism by which health data becomes usable for analytics, research, and secondary purposes without restriction, and the incentive to claim it is strong. Safe Harbor is mechanical but strict, and the actual knowledge condition still applies after all eighteen categories are removed. Expert Determination requires documentation that is frequently absent, and a dataset described as de-identified without either method properly applied remains fully protected PHI.

HOW TO AUDIT IT

1. For each de-identified dataset, establish which method was used and obtain the supporting evidence.
2. For Safe Harbor, verify all eighteen identifier categories were removed, including dates other than year and geographic subdivisions.
3. For Expert Determination, obtain the expert's analysis, qualifications, and documented conclusion.
4. Test the actual knowledge condition, including whether re-identification is possible using other data the entity holds.

EVIDENCE TO COLLECT

- De-identification method per dataset
- Safe Harbor identifier removal evidence
- Expert determination documentation and qualifications
- Re-identification risk analysis

HOW TO DOCUMENT IT

Record which method was applied and whether the supporting documentation exists, since a dataset treated as de-identified without a documented basis is being used and disclosed as though unregulated while remaining fully protected.

EXECUTIVE SUMMARY TREATMENT

Suggested language: datasets used for analytics are treated as de-identified without documentation of either de-identification method, and retain dates and geographic detail beyond what Safe Harbor permits, so they remain protected health information used without restriction.

Minimum necessary The minimum necessary standard

WHAT THE PROVISION REQUIRES

When using, disclosing, or requesting protected health information, a covered entity must make reasonable efforts to limit it to the minimum necessary to accomplish the intended purpose. The entity must identify persons or classes of persons in its workforce who need access, the categories of PHI they need, and conditions appropriate to that access, and must implement policies for routine and recurring disclosures and requests, with individual review for others. The standard does not apply to disclosures to or requests by a provider for treatment, to the individual, pursuant to a valid authorization, to the Secretary, as required by law, or as required for compliance.

WHY IT EXISTS

Minimum necessary is the principle that limits internal access as well as external disclosure, and it is what makes broad workforce access to complete records a violation rather than merely poor practice. The treatment exception is important and widely over-extended: it covers disclosures to providers for treatment, not general internal access on the assumption that any clinical role may need anything.

HOW TO AUDIT IT

1. Verify workforce roles and their PHI access needs are identified and documented.
2. Test actual access against documented need for a sample of roles, particularly non-clinical roles.
3. Check policies exist for routine disclosures and requests, with individual review for non-routine ones.
4. Examine whether the treatment exception is being applied beyond its actual scope.

EVIDENCE TO COLLECT

- Role-based access definitions with PHI categories
- Actual access extracts for comparison
- Routine disclosure and request policies

HOW TO DOCUMENT IT

Compare actual access against documented role need, since broad access granted for operational convenience is the characteristic minimum necessary finding and it is visible only by extracting real permissions.

EXECUTIVE SUMMARY TREATMENT

Suggested language: workforce members in administrative roles hold access to complete patient records without any documented determination of need, so access substantially exceeds the minimum necessary for their functions.

Required and Addressable Required and addressable specifications (45 CFR 164.306)**WHAT THE PROVISION REQUIRES**

Covered entities and business associates must ensure the confidentiality, integrity, and availability of all ePHI they create, receive, maintain, or transmit, protect against reasonably anticipated threats and impermissible uses or disclosures, and ensure workforce compliance. The Rule is deliberately flexible: entities may use any security measures that reasonably and appropriately implement the standards, taking account of size, complexity and capabilities, technical infrastructure, cost, and the probability and criticality of potential risks. Standards are mandatory. Implementation specifications are either required, in which case they must be implemented as stated, or addressable, in which case the entity must assess whether the specification is reasonable and appropriate and, if it is, implement it; if it is not, document why and implement an equivalent alternative measure where reasonable and appropriate.

WHY IT EXISTS

Addressable is the most misread term in HIPAA. It does not mean optional and it does not mean discretionary: it means the entity must make and document a reasoned determination, and either implement the specification or implement an equivalent alternative. An addressable specification neither implemented nor documented is a violation, and it is the single most common Security Rule finding.

HOW TO AUDIT IT

1. For each addressable specification not implemented, obtain the documented assessment of why it is not reasonable and appropriate.
2. Verify an equivalent alternative measure was implemented where the specification was not.
3. Check the flexibility factors were actually considered rather than cost alone.
4. Treat addressable specifications that are neither implemented nor documented as violations rather than gaps.

EVIDENCE TO COLLECT

- Addressable specification assessments with reasoning
- Alternative measures implemented
- Flexibility factor analysis

HOW TO DOCUMENT IT

List every addressable specification with its status: implemented, alternative implemented with documentation, or neither. The third category is the finding, and presenting it as a complete list is the most efficient way to convey Security Rule posture.

EXECUTIVE SUMMARY TREATMENT

Suggested language: a stated number of addressable implementation specifications, including encryption of ePHI at rest, are neither implemented nor supported by documented assessment, which is a violation of the Security Rule rather than an exercise of the flexibility it permits.

CHAPTER 2

Security Rule: Administrative Safeguards

Nine standards under 45 CFR 164.308, the largest section of the Security Rule and the one carrying the most weight. Implementation specifications are folded into their parent standard, with Required and Addressable status stated in each entry.

Start with 164.308(a)(1). The risk analysis is the foundation of the entire Security Rule: every other safeguard is calibrated to it, every addressable determination is justified by reference to it, and it is the most frequently cited deficiency in enforcement actions. Test its scope against the complete ePHI inventory, because partial coverage is the characteristic failure and a risk analysis that omits systems cannot support decisions about them.

Three standards produce most of the remaining findings. 164.308(a)(3) termination procedures, tested by measuring the interval from departure to access removal per system rather than in aggregate. 164.308(a)(7) contingency planning, where three of five specifications are required and the test is restoration, not backup completion. And 164.308(b), where the business associate population should be compiled independently from procurement and data flow evidence rather than read off the agreement register.

Quick reference: Admin Safeguards

Navigation: every reference and title below links to its full entry. Links shown in **orange** with a **CYB** or **AI** marker denote controls whose subject matter is specifically cybersecurity (CYB) or that are direct attachment points for AI system governance (AI). All others are **blue**.

Ref	Title	Primary evidence
164.308(a)(1)	Security management process	Risk analysis with scope, date, and methodology
164.308(a)(2)	Assigned security responsibility	Documented designation of the security official
164.308(a)(3) ADDR	Workforce security	Termination records with access removal timestamps per system
164.308(a)(4) ADDR	Information access management	Access authorization records against documented need
164.308(a)(5) ADDR	Security awareness and training	Training content and delivery records
164.308(a)(6)	Security incident procedures	Incident response procedures
164.308(a)(7) ADDR	Contingency plan	Backup configuration and completion records
164.308(a)(8)	Evaluation	Periodic evaluation reports
164.308(b)	Business associate contracts and other arrangements	Executed agreements with dates

164.308(a)(1) Security management process**WHAT THE PROVISION REQUIRES**

Implement policies and procedures to prevent, detect, contain, and correct security violations. Four specifications, all required: risk analysis, an accurate and thorough assessment of the potential risks and vulnerabilities to the confidentiality, integrity, and availability of ePHI held by the entity (R); risk management, implementing security measures sufficient to reduce risks and vulnerabilities to a reasonable and appropriate level (R); sanction policy, applying appropriate sanctions against workforce members who fail to comply with policies and procedures (R); and information system activity review, regularly reviewing records of system activity such as audit logs, access reports, and security incident tracking reports (R).

WHY IT EXISTS

The risk analysis is the foundation of the entire Security Rule: every other safeguard is calibrated to it, and the flexibility the Rule permits is only defensible by reference to it. It is also the most frequently cited deficiency in enforcement actions. An analysis that covers only some systems, or that was performed once and never updated, does not meet the accurate and thorough standard, and without it the entity cannot justify any of its addressable determinations.

HOW TO AUDIT IT

1. Obtain the risk analysis and test its scope against the complete ePHI inventory, since partial coverage is the characteristic failure.
2. Check it identifies specific threats and vulnerabilities rather than restating control categories.
3. Verify risk management measures trace to identified risks and were actually implemented.
4. Confirm information system activity review occurs and produces findings, and that the sanction policy has been applied where violations occurred.

EVIDENCE TO COLLECT

- Risk analysis with scope, date, and methodology
- ePHI inventory for scope comparison
- Risk management plan with implementation evidence
- Activity review records and sanction applications

HOW TO DOCUMENT IT

Compare risk analysis scope against the full ePHI inventory and record systems omitted. Record the analysis date, since a stale analysis cannot support current addressable determinations. Note whether activity review has ever produced a finding.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the risk analysis omits a stated number of systems holding ePHI and has not been updated in a stated period, so it does not meet the accurate and thorough standard and cannot support the organization's determinations on addressable specifications.

164.308(a)(2) Assigned security responsibility**WHAT THE PROVISION REQUIRES**

Identify the security official who is responsible for the development and implementation of the policies and procedures required by the Security Rule. This is a standard with no separate implementation specifications, so it is mandatory in itself.

WHY IT EXISTS

A named official creates accountability for the security programme. Where the role is unassigned, shared informally, or held by someone without authority or time, Security Rule obligations fall between functions and no one owns the risk analysis, the addressable determinations, or the incident response.

HOW TO AUDIT IT

1. Verify a security official is identified by name and the identification is documented.
2. Check the official has the authority and resources to develop and implement the required policies.
3. Confirm the role is current rather than assigned to a departed individual.

EVIDENCE TO COLLECT

- Documented designation of the security official
- Role description with authority and reporting line

HOW TO DOCUMENT IT

Record whether the designation is documented and current, since an outdated designation naming a departed individual is a common and easily verified finding.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the designated security official left the organization a stated period ago and no replacement has been documented, so no individual is accountable for the Security Rule programme.

164.308(a)(3) Workforce security**WHAT THE PROVISION REQUIRES**

Implement policies and procedures to ensure all workforce members have appropriate access to ePHI and to prevent those who do not have access from obtaining it. Three addressable specifications: authorization and supervision of workforce members who work with ePHI or in locations where it might be accessed (A); workforce clearance procedure, determining that a workforce member's access is appropriate (A); and termination procedures, terminating access when employment ends or when access is no longer appropriate (A).

WHY IT EXISTS

Termination procedures are addressable in form but almost never defensible to omit: an entity that cannot show it removes access when people leave has departed workforce members retaining access to ePHI. This standard pairs directly with the technical access controls, and the failure is usually operational rather than technical, with the security team unaware of a departure until well after it happened.

HOW TO AUDIT IT

1. Sample terminations and measure the interval between departure and access removal across every system holding ePHI.
2. Reconcile the active account population against current workforce records.
3. Check clearance procedures determine access appropriateness before access is granted.
4. Where these specifications are not implemented, obtain the documented assessment and any alternative measure.

EVIDENCE TO COLLECT

- Termination records with access removal timestamps per system
- Active accounts reconciled against workforce records
- Clearance and authorization procedures
- Addressable assessments where not implemented

HOW TO DOCUMENT IT

Record access removal intervals per system rather than in aggregate, since the outlying system that stays open is the finding the average conceals. Note any accounts belonging to departed workforce members.

EXECUTIVE SUMMARY TREATMENT

Suggested language: a stated number of accounts belonging to departed workforce members retain access to systems containing ePHI, the oldest a stated period after termination.

164.308(a)(4) Information access management**WHAT THE PROVISION REQUIRES**

Implement policies and procedures for authorizing access to ePHI consistent with the Privacy Rule. Three specifications: isolating health care clearinghouse functions, where a clearinghouse is part of a larger organization, protecting ePHI from unauthorized access by the larger organization (R); access authorization, policies for granting access to ePHI through a workstation, transaction, program, process, or other mechanism (A); and access establishment and modification, policies to establish, document, review, and modify a user's right of access (A).

WHY IT EXISTS

This standard is where the Security Rule connects to the Privacy Rule's minimum necessary requirement: access must be authorized consistently with what the Privacy Rule permits. The review element of access establishment and modification is the part most often absent, so access accumulates as people change roles and is never reassessed.

HOW TO AUDIT IT

1. Verify access is authorized against documented need consistent with minimum necessary.
2. Check periodic access review occurs and produces revocations, since a review that removes nothing is not functioning.
3. Test access for role-changed workforce members to see whether prior access was removed.
4. Where a clearinghouse function exists within a larger organization, verify isolation.

EVIDENCE TO COLLECT

- Access authorization records against documented need
- Access review records with revocation counts
- Role change access modification evidence
- Clearinghouse isolation evidence where applicable

HOW TO DOCUMENT IT

Report the access review revocation rate, since a review across a substantial population that removes nothing indicates confirmation rather than review. Note role changes where prior access persisted.

EXECUTIVE SUMMARY TREATMENT

Suggested language: access reviews were performed but removed no access across the period, and workforce members who changed roles retain access from previous positions, so access accumulates without effective reassessment.

164.308(a)(5) Security awareness and training**WHAT THE PROVISION REQUIRES**

Implement a security awareness and training program for all workforce members, including management. Four addressable specifications: security reminders, periodic security updates (A); protection from malicious software, procedures for guarding against, detecting, and reporting malicious software (A); log-in monitoring, procedures for monitoring log-in attempts and reporting discrepancies (A); and password management, procedures for creating, changing, and safeguarding passwords (A).

WHY IT EXISTS

The training programme itself is a mandatory standard even though all four specifications beneath it are addressable, so an entity with no training programme is in breach regardless of its addressable determinations. Training must reach all workforce members including management, and the workforce definition extends to volunteers and trainees under the entity's direct control, not only employees.

HOW TO AUDIT IT

1. Verify a training programme exists and reconcile completion against the complete workforce, including contractors, volunteers, and management.
2. Check periodic security reminders are delivered rather than training being a one-time event at onboarding.
3. Verify malicious software protection, log-in monitoring, and password procedures are implemented or documented as addressable determinations.
4. Test effect by asking workforce members how they would report a suspected security incident.

EVIDENCE TO COLLECT

- Training content and delivery records
- Completion reconciled to the full workforce definition
- Security reminder evidence
- Log-in monitoring configuration and results

HOW TO DOCUMENT IT

Reconcile training completion against the full workforce definition rather than the employee list, since volunteers, trainees, and contractors under direct control are within scope and routinely omitted.

EXECUTIVE SUMMARY TREATMENT

Suggested language: security training is delivered at onboarding only with no periodic reminders, and a stated proportion of the workforce, concentrated among contractors and volunteers, has no completion record.

164.308(a)(6) Security incident procedures**WHAT THE PROVISION REQUIRES**

Implement policies and procedures to address security incidents. One specification, required: response and reporting, meaning identify and respond to suspected or known security incidents, mitigate to the extent practicable the harmful effects of incidents that are known to the entity, and document incidents and their outcomes (R). A security incident is the attempted or successful unauthorized access, use, disclosure, modification, or destruction of information, or interference with system operations.

WHY IT EXISTS

The definition includes attempted as well as successful incidents, which is broader than most entities operate to. The documentation obligation is explicit and separate: incidents and their outcomes must be documented, and an entity that responds well but keeps no record has not met the specification. This is also distinct from the Breach Notification Rule, and every breach is a security incident while not every security incident is a breach.

HOW TO AUDIT IT

1. Verify incident procedures exist and cover identification, response, mitigation, and documentation.
2. Obtain the incident log and assess whether the volume is plausible given the environment.
3. Check that incidents are documented with their outcomes, not only logged as tickets.
4. Examine how security incidents are assessed against the breach definition.

EVIDENCE TO COLLECT

- Incident response procedures
- Incident log with outcomes documented
- Breach assessment linkage

HOW TO DOCUMENT IT

Record incident volume and assess plausibility, since a very low or zero count over a substantial period generally indicates a recognition or recording failure rather than an incident-free environment.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the organization recorded no security incidents across the period despite evidence of malware detections and failed access attempts, so incidents are occurring without being identified, documented, or assessed against the breach definition.

164.308(a)(7) Contingency plan**WHAT THE PROVISION REQUIRES**

Establish policies and procedures for responding to an emergency or other occurrence such as fire, vandalism, system failure, or natural disaster that damages systems containing ePHI. Five specifications: data backup plan, establishing and implementing procedures to create and maintain retrievable exact copies of ePHI (R); disaster recovery plan, procedures to restore any loss of data (R); emergency mode operation plan, procedures to enable continuation of critical business processes for protection of ePHI while operating in emergency mode (R); testing and revision procedures, periodic testing and revision of contingency plans (A); and applications and data criticality analysis, assessing the relative criticality of specific applications and data (A).

WHY IT EXISTS

Three of the five specifications are required, making this one of the more demanding standards. The emergency mode operation plan is the one most often absent, because entities plan for recovery without planning how ePHI stays protected while they are operating degraded. Testing is addressable, but an untested plan combined with required backup and recovery obligations is difficult to defend.

HOW TO AUDIT IT

1. Verify backups exist and, critically, that restoration has been tested rather than only that backups complete.
2. Check the retrievable exact copies requirement is met, including for ePHI outside the primary system.
3. Obtain the emergency mode operation plan and confirm it addresses protection of ePHI during degraded operation.
4. Examine whether contingency plans have been tested and revised, or whether an addressable determination is documented.

EVIDENCE TO COLLECT

- Backup configuration and completion records
- Restoration test results
- Disaster recovery and emergency mode operation plans
- Testing records or addressable assessment

HOW TO DOCUMENT IT

Distinguish backup completion from restoration testing explicitly, since these are consistently conflated and only the latter demonstrates the required retrievable exact copies. Note whether backups are reachable from production.

EXECUTIVE SUMMARY TREATMENT

Suggested language: backup restoration has never been tested, no emergency mode operation plan exists, and backups are reachable using production credentials, so the required contingency capability is unverified and would likely be destroyed by the same event it protects against.

164.308(a)(8) Evaluation**WHAT THE PROVISION REQUIRES**

Perform a periodic technical and nontechnical evaluation, based initially on the standards implemented under the Security Rule and subsequently in response to environmental or operational changes affecting the security of ePHI, that establishes the extent to which policies and procedures meet the requirements of the Rule. This is a standard with no separate specifications, so it is mandatory.

WHY IT EXISTS

Evaluation is the Rule's self-assessment obligation and is distinct from the risk analysis: the risk analysis identifies risks to ePHI, while the evaluation establishes whether the entity's policies and procedures meet the Rule's requirements. Entities frequently perform one and treat it as satisfying both. The trigger includes environmental and operational change, so a significant system change or acquisition requires re-evaluation rather than waiting for the next cycle.

HOW TO AUDIT IT

1. Obtain evaluations and confirm they assess compliance with the Rule, distinct from the risk analysis.
2. Check evaluations are both technical and nontechnical.
3. Verify evaluation followed significant environmental or operational changes, not only a fixed schedule.
4. Examine whether findings were remediated.

EVIDENCE TO COLLECT

- Periodic evaluation reports
- Change events that should have triggered evaluation
- Remediation of evaluation findings

HOW TO DOCUMENT IT

Record whether a distinct evaluation exists or whether the risk analysis is being used to satisfy both obligations, since these are separate requirements with different purposes.

EXECUTIVE SUMMARY TREATMENT

Suggested language: no evaluation distinct from the risk analysis has been performed, and significant system changes during the period did not trigger re-evaluation, so the organization has not established whether its policies and procedures meet the Rule's requirements.

164.308(b) Business associate contracts and other arrangements**WHAT THE PROVISION REQUIRES**

A covered entity may permit a business associate to create, receive, maintain, or transmit ePHI on its behalf only if it obtains satisfactory assurances, documented through a written contract or other arrangement, that the business associate will appropriately safeguard the information. The same applies between a business associate and its subcontractors. One specification, required: written contract or other arrangement documenting the satisfactory assurances (R).

WHY IT EXISTS

This is the mechanism by which Security Rule obligations extend down the supply chain, and its failures are structural: agreements missing entirely, agreements that predate the Omnibus Rule and do not reflect current requirements, and subcontractor chains where flow-down stops after the first tier. Satisfactory assurances also implies some basis for the assurance rather than mere execution of a document.

HOW TO AUDIT IT

1. Reconcile executed agreements against the independently compiled population of entities handling ePHI.
2. Check agreement content reflects current requirements rather than pre-Omnibus templates.
3. Verify flow-down to subcontractors beyond the first tier.
4. Examine what basis exists for the satisfactory assurances beyond contract execution.

EVIDENCE TO COLLECT

- Executed agreements with dates
- Independently compiled entity population
- Subcontractor flow-down evidence
- Due diligence supporting satisfactory assurances

HOW TO DOCUMENT IT

Record agreements that predate the Omnibus Rule, since these frequently omit direct business associate liability and subcontractor flow-down obligations and are effectively out of date.

EXECUTIVE SUMMARY TREATMENT

Suggested language: a stated number of business associate agreements predate the Omnibus Rule and omit subcontractor flow-down obligations, and a further number of vendors handling ePHI have no agreement at all.

CHAPTER 3

Security Rule: Physical Safeguards

Four standards under 45 CFR 164.310. Physical access defeats technical controls entirely, so this section matters more than its unglamorous reputation suggests.

Two of the four standards are mandatory in themselves with no specifications beneath them: workstation use and workstation security. These are assessed by observation rather than by reading policy. Walk the floor: screens visible from public areas and unattended sessions are immediately evidenced and difficult to dispute.

164.310(d) contains two required specifications that recur in enforcement actions, disposal and media re-use, because the failure is concrete and provable when a device leaves with recoverable ePHI on it. Reformatting does not render data unrecoverable. Reconcile the asset register against disposal and sanitization records. The remaining orange standards, 164.310(a) and the addressable half of (d), warrant the usual question: where a specification is not implemented, does a documented determination exist?

Quick reference: Physical Safeguards

Navigation: every reference and title below links to its full entry. Links shown in **orange** with a **CYB** or **AI** marker denote controls whose subject matter is specifically cybersecurity (CYB) or that are direct attachment points for AI system governance (AI). All others are **blue**.

Ref	Title	Primary evidence
164.310(a) ADDR	Facility access controls	Facility security plan and access control procedures
164.310(b)	Workstation use	Workstation use policies by class
164.310(c)	Workstation security	Physical safeguard measures by workstation type
164.310(d) ADDR	Device and media controls	Disposal procedures and sanitization verification

164.310(a) Facility access controls**WHAT THE PROVISION REQUIRES**

Implement policies and procedures to limit physical access to electronic information systems and the facilities in which they are housed, while ensuring properly authorized access is allowed. Four addressable specifications: contingency operations, procedures allowing facility access to support restoration of lost data under the disaster recovery and emergency mode operation plans (A); facility security plan, policies to safeguard the facility and equipment from unauthorized physical access, tampering, and theft (A); access control and validation procedures, procedures to control and validate access based on role or function, including visitor control and control of access to software programs for testing and revision (A); and maintenance records, policies to document repairs and modifications to the physical security components of a facility (A).

WHY IT EXISTS

Physical access defeats technical controls entirely: someone standing at a server or an unattended workstation is past the access control layer. All four specifications are addressable, which means an entity choosing not to implement them owes a documented determination for each, and blanket non-implementation with no documentation across all four is a common and clear-cut finding.

HOW TO AUDIT IT

1. Verify physical access to facilities housing ePHI systems is controlled and limited to authorized persons.
2. Check visitor control operates in practice, particularly in areas where ePHI systems or displays are visible.
3. Reconcile physical access authorizations against current workforce, including for departed members.
4. Where specifications are not implemented, obtain the documented assessment and alternative measures.

EVIDENCE TO COLLECT

- Facility security plan and access control procedures
- Physical access authorization list reconciled to workforce
- Visitor control records
- Addressable assessments where not implemented

HOW TO DOCUMENT IT

Reconcile the physical access list against workforce departures, and record whether contingency operations access is addressed, since restoration during an emergency frequently requires facility access that nobody has planned for.

EXECUTIVE SUMMARY TREATMENT

Suggested language: none of the four facility access control specifications is implemented and no addressable determination is documented for any of them, and former workforce members retain physical access to areas housing ePHI systems.

164.310(b) Workstation use**WHAT THE PROVISION REQUIRES**

Implement policies and procedures that specify the proper functions to be performed, the manner in which those functions are to be performed, and the physical attributes of the surroundings of a specific workstation or class of workstation that can access ePHI. This is a standard with no separate specifications, so it is mandatory.

WHY IT EXISTS

Workstation use governs what may be done at a workstation and in what environment, which is where remote and mobile working creates exposure the entity has not considered. A workstation in a home office or a public space has different surroundings from one in a controlled clinical area, and the standard requires the entity to have addressed that rather than leaving it to individual judgment.

HOW TO AUDIT IT

1. Verify policies specify proper functions, manner of performance, and physical surroundings by workstation class.
2. Check remote and mobile workstations are covered, since these are where surroundings are least controlled.
3. Test whether the policy reflects actual working patterns.

EVIDENCE TO COLLECT

- Workstation use policies by class
- Remote working provisions
- Workstation inventory by class

HOW TO DOCUMENT IT

Record whether remote workstations are addressed, since policies written for a clinical setting frequently do not contemplate the environments where staff now actually work.

EXECUTIVE SUMMARY TREATMENT

Suggested language: workstation use policies address on-site clinical workstations only, so the remote environments where a substantial proportion of ePHI access now occurs are ungoverned.

164.310(c) Workstation security**WHAT THE PROVISION REQUIRES**

Implement physical safeguards for all workstations that access ePHI, to restrict access to authorized users. This is a standard with no separate specifications, so it is mandatory. It concerns the physical protection of the workstation itself, as distinct from the policies governing its use under 164.310(b).

WHY IT EXISTS

This is the standard addressing unattended workstations, screens visible to passers-by, and devices that can be removed. It applies to all workstations accessing ePHI, which includes mobile devices and home equipment, and physical safeguards there are materially harder to assure than in a controlled facility.

HOW TO AUDIT IT

1. Observe workstations in practice, checking screen positioning and whether unattended sessions are exposed.
2. Verify physical safeguards exist for portable and remote devices accessing ePHI.
3. Check safeguards restrict access to authorized users rather than merely existing.

EVIDENCE TO COLLECT

- Physical safeguard measures by workstation type
- Observation evidence
- Portable device safeguards

HOW TO DOCUMENT IT

Record observations of workstations in situ, since this standard is assessed by looking rather than by reading policy, and screens visible from public areas are immediately evidenced.

EXECUTIVE SUMMARY TREATMENT

Suggested language: workstations displaying ePHI are positioned so that screens are visible from public waiting areas, and portable devices accessing ePHI have no physical safeguards specified.

164.310(d) Device and media controls**WHAT THE PROVISION REQUIRES**

Implement policies and procedures governing the receipt and removal of hardware and electronic media containing ePHI into and out of a facility, and movement within the facility. Four specifications: disposal, addressing final disposition of ePHI and the hardware or media on which it is stored (R); media re-use, procedures for removal of ePHI from electronic media before re-use (R); accountability, maintaining a record of movements of hardware and media and the person responsible (A); and data backup and storage, creating a retrievable exact copy of ePHI when needed before equipment movement (A).

WHY IT EXISTS

Disposal and media re-use are both required, and both are common enforcement subjects because the failure is concrete and provable: a device leaves the entity with recoverable ePHI on it. Standard deletion and reformatting do not remove data recoverably, so the procedures must specify a method that actually works and must be verified rather than assumed.

HOW TO AUDIT IT

1. Verify disposal procedures specify a method that renders ePHI unrecoverable and that disposal is verified.
2. Reconcile devices disposed against sanitization records.
3. Check media re-use procedures remove ePHI before reallocation, including for devices moving between departments.
4. Examine accountability records for hardware movement, or the documented addressable determination.

EVIDENCE TO COLLECT

- Disposal procedures and sanitization verification
- Asset disposal reconciliation
- Media re-use procedures
- Movement records or addressable assessment

HOW TO DOCUMENT IT

Reconcile the asset register against disposal and sanitization records, and record devices disposed without verified sanitization, since these are unambiguous breaches of a required specification.

EXECUTIVE SUMMARY TREATMENT

Suggested language: a stated number of devices were disposed of without verified sanitization of ePHI, and reformatting is relied upon as the disposal method, which does not render data unrecoverable.

Security Rule: Technical Safeguards

Five standards under 45 CFR 164.312, assessed by examining configuration rather than documentation. Three of the five contain addressable specifications, including the two encryption provisions.

Encryption is addressable at rest under 164.312(a) and in transit under 164.312(e), which is widely misread as meaning optional. In practice it is very difficult to argue that encryption is not reasonable and appropriate for portable devices or for transmission over open networks, and its absence has featured in many enforcement actions. Where it is absent, the question is whether a documented determination exists, and usually it does not.

Two required items carry disproportionate weight. Unique user identification under 164.312(a) is breached by every shared clinical account still in use, and shared accounts simultaneously defeat the audit controls at 164.312(b). And 164.312(b) requires both recording and examining activity: logs collected and never reviewed detect nothing. Test specifically whether access to a record by someone with no treatment relationship would be detected, since that is the characteristic health care privacy incident.

Quick reference: Technical Safeguards

Navigation: every reference and title below links to its full entry. Links shown in [orange](#) with a [CYB](#) or [AI](#) marker denote controls whose subject matter is specifically cybersecurity (CYB) or that are direct attachment points for AI system governance (AI). All others are [blue](#).

Ref	Title	Primary evidence
164.312(a) ADDR	Access control	Account listing identifying shared or generic accounts
164.312(b)	Audit controls	Audit mechanism coverage across ePHI systems
164.312(c) ADDR	Integrity	Integrity protection policies and procedures
164.312(d)	Person or entity authentication	Authentication configuration across access paths
164.312(e) ADDR	Transmission security	Transmission encryption configuration by path

164.312(a) Access control**WHAT THE PROVISION REQUIRES**

Implement technical policies and procedures for electronic information systems that maintain ePHI to allow access only to persons or software programs that have been granted access rights under 164.308(a)(4). Four specifications: unique user identification, assigning a unique name or number for identifying and tracking user identity (R); emergency access procedure, procedures for obtaining necessary ePHI during an emergency (R); automatic logoff, electronic procedures terminating an electronic session after a predetermined time of inactivity (A); and encryption and decryption, a mechanism to encrypt and decrypt ePHI (A).

WHY IT EXISTS

Unique user identification is required and is the foundation of accountability: shared accounts make it impossible to attribute access to an individual, which defeats audit controls and any subsequent investigation. Encryption at rest is addressable, which is widely misread as optional; in practice it is difficult to argue encryption is not reasonable and appropriate for portable devices, and its absence has featured in many enforcement actions.

HOW TO AUDIT IT

1. Identify any shared or generic accounts with access to ePHI, since these breach a required specification.
2. Verify emergency access procedures exist and have been tested, and that emergency access is logged.
3. Check automatic logoff configuration and encryption status, and where absent obtain the documented determination.
4. Assess whether an encryption determination of not reasonable and appropriate is defensible, particularly for portable devices.

EVIDENCE TO COLLECT

- Account listing identifying shared or generic accounts
- Emergency access procedures and use logs
- Automatic logoff configuration
- Encryption coverage and addressable assessment

HOW TO DOCUMENT IT

List shared accounts with ePHI access individually, since these breach a required specification and simultaneously undermine audit controls. Record encryption coverage against the documented determination.

EXECUTIVE SUMMARY TREATMENT

Suggested language: shared clinical accounts with access to ePHI remain in use, breaching the required unique user identification specification and making it impossible to attribute access to an individual in any investigation.

164.312(b) Audit controls**WHAT THE PROVISION REQUIRES**

Implement hardware, software, or procedural mechanisms that record and examine activity in information systems that contain or use ePHI. This is a standard with no separate specifications, so it is mandatory.

WHY IT EXISTS

The standard requires both recording and examining, and the examination limb is where entities fail: logs are collected diligently and never reviewed, which detects nothing. Audit controls are also what make inappropriate access by authorized users visible, which is the most common form of impermissible access in health care and is invisible to access control alone.

HOW TO AUDIT IT

1. Verify audit mechanisms record activity in all systems containing ePHI, not only the primary record system.
2. Check that recorded activity is actually examined, with evidence of review and findings.
3. Test whether inappropriate access by an authorized user would be detected, such as access to a record with no treatment relationship.
4. Confirm audit records are protected from modification by those whose activity they record.

EVIDENCE TO COLLECT

- Audit mechanism coverage across ePHI systems
- Review records and findings
- Inappropriate access detection capability
- Audit record protection

HOW TO DOCUMENT IT

Record whether logs are examined as well as recorded, and whether any review has produced a finding. Test specifically whether access without a treatment relationship would be detected, since this is the characteristic health care privacy incident.

EXECUTIVE SUMMARY TREATMENT

Suggested language: audit logs are recorded but never examined, and the organization has no capability to detect access to records by workforce members with no treatment or business relationship to the patient concerned.

164.312(c) Integrity**WHAT THE PROVISION REQUIRES**

Implement policies and procedures to protect ePHI from improper alteration or destruction. One addressable specification: mechanism to authenticate ePHI, meaning electronic mechanisms to corroborate that ePHI has not been altered or destroyed in an unauthorized manner (A).

WHY IT EXISTS

Integrity failures in health information have direct clinical consequences: an altered medication record or test result can cause patient harm. The standard covers improper alteration and destruction whether malicious or accidental, and accidental corruption through system error or migration is the more common cause.

HOW TO AUDIT IT

1. Verify policies and procedures protect ePHI from improper alteration and destruction.
2. Check mechanisms exist to detect unauthorized alteration, or obtain the addressable determination.
3. Examine integrity controls during data migration and system transitions, where corruption commonly occurs.

EVIDENCE TO COLLECT

- Integrity protection policies and procedures
- Authentication mechanisms or addressable assessment
- Migration integrity controls

HOW TO DOCUMENT IT

Record whether any mechanism would detect unauthorized alteration of ePHI, since without one an integrity failure would be discovered only through its clinical consequences.

EXECUTIVE SUMMARY TREATMENT

Suggested language: no mechanism exists to detect unauthorized alteration of ePHI and no addressable determination is documented, so corruption or tampering would be discovered only when it affected patient care.

164.312(d) Person or entity authentication**WHAT THE PROVISION REQUIRES**

Implement procedures to verify that a person or entity seeking access to ePHI is the one claimed. This is a standard with no separate specifications, so it is mandatory.

WHY IT EXISTS

Authentication is what connects a unique user identifier to an actual person, and without it the identifier proves nothing. The standard does not prescribe a method, so single-factor authentication can satisfy it, but the risk analysis must support that choice and for remote access to ePHI it increasingly does not.

HOW TO AUDIT IT

1. Verify authentication is required for all access to ePHI, including administrative and remote access paths.
2. Assess whether the authentication strength is supported by the risk analysis.
3. Check for access paths that bypass authentication, including service accounts and integrations.
4. Examine multi-factor coverage for remote access.

EVIDENCE TO COLLECT

- Authentication configuration across access paths
- Risk analysis support for the chosen method
- Remote access authentication

HOW TO DOCUMENT IT

Record authentication strength for remote access specifically, and whether the risk analysis addresses it, since single-factor remote access to ePHI is difficult to defend against a current risk analysis.

EXECUTIVE SUMMARY TREATMENT

Suggested language: remote access to systems containing ePHI requires single-factor authentication only, and the risk analysis does not address remote access risk, so the chosen method is unsupported.

164.312(e) Transmission security**WHAT THE PROVISION REQUIRES**

Implement technical security measures to guard against unauthorized access to ePHI being transmitted over an electronic communications network. Two addressable specifications: integrity controls, measures to ensure electronically transmitted ePHI is not improperly modified without detection until disposed of (A); and encryption, a mechanism to encrypt ePHI whenever deemed appropriate (A).

WHY IT EXISTS

Transmission encryption is addressable but very difficult to argue against for transmission over open networks, and unencrypted email containing ePHI is among the most common and most easily evidenced findings. Internal transmission is frequently overlooked entirely, on an assumption that the internal network is trusted.

HOW TO AUDIT IT

1. Verify encryption is applied to ePHI transmitted over open networks, examining actual configuration.
2. Check internal transmission of ePHI, including between systems and to interfaces.
3. Examine email specifically, since ePHI sent by unencrypted email is common and provable.
4. Where encryption is not applied, obtain the documented addressable determination.

EVIDENCE TO COLLECT

- Transmission encryption configuration by path
- Email handling of ePHI
- Internal transmission protection
- Addressable assessments

HOW TO DOCUMENT IT

Record every transmission path carrying ePHI and its encryption status, including email and internal interfaces, since coverage is usually partial and the gaps are specific and evidenceable.

EXECUTIVE SUMMARY TREATMENT

Suggested language: ePHI is transmitted by unencrypted email and over internal interfaces without encryption, with no documented determination that encryption is not reasonable and appropriate for those paths.

Security Rule: Organizational and Documentation Requirements

Three entries covering 45 CFR 164.314 and 164.316. Blue throughout, since none contains addressable specifications.

164.314(a) specifies what a business associate agreement must actually contain, as distinct from 164.308(b) which requires that one exist. The provision that matters operationally is security incident reporting, and the question to ask is arithmetic: does the reporting timeframe in the agreement leave the covered entity any time to meet its own 60-day breach notification deadline? A business associate permitted 60 days leaves none.

164.316 carries three required specifications, of which six-year retention is the one most often failed silently. It applies to superseded policy versions and to records of every required action, activity, and assessment. Entities that discard prior versions lose the ability to demonstrate what safeguards were in effect at the time of a past incident, which is precisely when the question gets asked.

Quick reference: Organizational Reqs

Navigation: every reference and title below links to its full entry. Links shown in **orange** with a **cyb** or **ai** marker denote controls whose subject matter is specifically cybersecurity (CYB) or that are direct attachment points for AI system governance (AI). All others are **blue**.

Ref	Title	Primary evidence
164.314(a)	Business associate contracts or other arrangements	Agreement terms mapped to requirements
164.314(b)	Requirements for group health plans	Plan documents with required provisions
164.316	Policies, procedures, and documentation requirements	Policy and procedure set with version history

164.314(a) Business associate contracts or other arrangements**WHAT THE PROVISION REQUIRES**

The contract or other arrangement between a covered entity and business associate must provide that the business associate will comply with the Security Rule, ensure that any subcontractors that create, receive, maintain, or transmit ePHI on its behalf agree to comply with the applicable requirements, and report to the covered entity any security incident of which it becomes aware, including breaches of unsecured PHI. Where both parties are governmental entities, other arrangements such as a memorandum of understanding may substitute.

WHY IT EXISTS

This section specifies what the agreement must actually contain, as distinct from 164.308(b) which requires that one exist. The incident reporting term is operationally the most significant: without it the covered entity depends on discovering business associate incidents by other means, and most breaches affecting covered entities originate with business associates.

HOW TO AUDIT IT

1. Check agreements contain each required term, particularly subcontractor compliance and security incident reporting.
2. Verify incident reporting obligations specify timing sufficient to meet the covered entity's own breach deadlines.
3. Examine whether business associates have actually reported incidents, since silence may indicate non-reporting rather than an absence of incidents.
4. Confirm other arrangements between governmental entities meet the equivalent requirements.

EVIDENCE TO COLLECT

- Agreement terms mapped to requirements
- Incident reporting provisions with timing
- Business associate incident reports received

HOW TO DOCUMENT IT

Record whether incident reporting timelines in agreements would allow the covered entity to meet its own 60-day notification deadline, since a business associate permitted 60 days to report leaves no time at all.

EXECUTIVE SUMMARY TREATMENT

Suggested language: business associate agreements permit up to 60 days for incident reporting, which leaves the organization no time to meet its own notification deadline, and no business associate has reported an incident across the period.

164.314(b) Requirements for group health plans**WHAT THE PROVISION REQUIRES**

Except where the only ePHI disclosed is summary health information for specified purposes or enrollment and disenrollment information, a group health plan must ensure its plan documents provide that the plan sponsor will reasonably and appropriately safeguard ePHI created, received, maintained, or transmitted to or by the plan sponsor on behalf of the group health plan. The plan documents must require the sponsor to implement administrative, physical, and technical safeguards, ensure adequate separation supported by reasonable and appropriate security measures, ensure agents to whom it provides ePHI agree to implement equivalent measures, and report security incidents to the group health plan.

WHY IT EXISTS

This provision governs the relationship between a group health plan and its sponsor, typically the employer, and the adequate separation requirement is the substantive one: it prevents ePHI held for plan administration flowing into employment decision-making. The failure mode is a plan sponsor whose HR function accesses plan ePHI without separation, which is both a Security Rule and a Privacy Rule issue.

HOW TO AUDIT IT

1. Where a group health plan exists, verify plan documents contain the required provisions.
2. Test adequate separation in practice: can plan administration ePHI be accessed by those making employment decisions?
3. Check agents receiving ePHI have agreed to equivalent measures.
4. Verify incident reporting from sponsor to plan operates.

EVIDENCE TO COLLECT

- Plan documents with required provisions
- Separation measures and access evidence
- Agent agreements

HOW TO DOCUMENT IT

Test adequate separation by examining actual access rather than the plan document, since the document commonly recites the requirement while access controls do not enforce it.

EXECUTIVE SUMMARY TREATMENT

Suggested language: plan documents recite the adequate separation requirement, but HR personnel involved in employment decisions hold access to group health plan ePHI, so the separation is not enforced in practice.

164.316 Policies, procedures, and documentation requirements**WHAT THE PROVISION REQUIRES**

Implement reasonable and appropriate policies and procedures to comply with the Security Rule standards and specifications, which may be changed at any time provided changes are documented and implemented. Maintain the policies and procedures in written, which may be electronic, form, and where an action, activity, or assessment is required to be documented, maintain a written record of it. Three specifications, all required: retain documentation for six years from the date of its creation or the date when it last was in effect, whichever is later (R); make documentation available to those responsible for implementing the procedures to which it pertains (R); and review documentation periodically and update as needed in response to environmental or operational changes affecting the security of ePHI (R).

WHY IT EXISTS

The six-year retention period applies to documentation of every required action, activity, and assessment, which includes risk analyses, addressable determinations, incident records, and training records. Entities that discard superseded policies lose the ability to demonstrate what was in effect at the time of a past incident, which is precisely when it matters.

HOW TO AUDIT IT

1. Verify policies and procedures exist covering the Security Rule standards.
2. Check six-year retention is applied, including to superseded versions and to records of required activities.
3. Confirm documentation is available to those who must implement it, rather than held centrally and unpublished.
4. Verify periodic review occurs and is triggered by environmental and operational change.

EVIDENCE TO COLLECT

- Policy and procedure set with version history
- Retention evidence including superseded versions
- Availability and distribution evidence
- Review records

HOW TO DOCUMENT IT

Check whether superseded policy versions are retained for six years, since the ability to demonstrate what was in effect at the time of a past incident depends on it and destruction of prior versions is common.

EXECUTIVE SUMMARY TREATMENT

Suggested language: superseded policies are not retained, so the organization cannot demonstrate which safeguards were in effect at the time of incidents occurring earlier in the six-year retention period.

Privacy Rule: Uses and Disclosures

Seven entries covering 45 CFR 164.502 through 164.514. Blue throughout: the Privacy Rule has no addressable concept, so every provision here is mandatory with no documented-alternative route available.

The architecture is default prohibition. A covered entity may not use or disclose PHI except as the Rule permits or requires, which is the opposite of the assumption most workforce members operate under. The most productive test is therefore to sample actual disclosures and map each to the specific permission relied upon; a disclosure that cannot be mapped is impermissible rather than merely undocumented.

Two areas concentrate the findings. 164.512 law enforcement disclosures, where staff face immediate pressure from an authority figure and the conditions differ substantially depending on the legal process presented. And the verification requirement in 164.514(h), where telephone disclosure processes are commonly informal. That is the channel social engineering against health care organizations actually exploits, so test it directly.

Quick reference: Uses and Disclosures

Navigation: every reference and title below links to its full entry. Links shown in orange with a **CYB** or **AI** marker denote controls whose subject matter is specifically cybersecurity (CYB) or that are direct attachment points for AI system governance (AI). All others are blue.

Ref	Title	Primary evidence
164.502	Uses and disclosures of PHI: general rules	Permission mapping for sampled disclosures
164.504	Organizational requirements: BAs, hybrid entities, and organized arrangements	BA contract terms mapped to requirements
164.506	Treatment, payment, and health care operations	Activity characterisation against the operations definition
164.508	Uses and disclosures for which an authorization is required	Sampled authorizations checked element by element
164.510	Uses and disclosures requiring an opportunity to agree or object	Directory opt-out records and their operational effect
164.512	Disclosures not requiring authorization or an opportunity to object	Disclosure records with paragraph relied upon
164.514(d)-(h)	Minimum necessary implementation and other requirements	Verification procedures and evidence of application

164.502 Uses and disclosures of PHI: general rules

WHAT THE PROVISION REQUIRES

A covered entity may not use or disclose protected health information except as permitted or required by the Privacy Rule. Disclosure is required in two circumstances: to the individual when they request access or an accounting, and to the Secretary for compliance investigation or enforcement. Permitted uses and disclosures include to the individual, for treatment, payment and health care operations, with the individual's agreement or opportunity to object, incident to a permitted use or disclosure, for the public interest and benefit activities, and as a limited data set. A business associate may use or disclose PHI only as permitted by its agreement or as required by law. The section also addresses personal representatives, deceased individuals, and the prohibition on use or disclosure of genetic information for underwriting.

WHY IT EXISTS

This is the default-prohibition architecture of the Privacy Rule: everything is forbidden unless affirmatively permitted, which is the opposite of the assumption most workforce members operate under. The incident-to permission is the safety valve that makes ordinary clinical practice workable, but it depends on reasonable safeguards and minimum necessary being applied, so it is not a general excuse for overheard or overseen PHI.

HOW TO AUDIT IT

1. For a sample of uses and disclosures, identify the specific permission relied upon.
2. Verify personal representative determinations are made consistently with the Rule and applicable state law.
3. Check that disclosures required to the individual and to the Secretary are recognised as mandatory.
4. Examine reliance on the incident-to permission and whether reasonable safeguards support it.

EVIDENCE TO COLLECT

- Permission mapping for sampled disclosures
- Personal representative policies and determinations
- Safeguards supporting incident-to disclosures

HOW TO DOCUMENT IT

Record disclosures with no identifiable permission, since the default is prohibition and an unmapped disclosure is an impermissible one until a permission is established.

EXECUTIVE SUMMARY TREATMENT

Suggested language: a stated number of routine disclosures could not be mapped to any permission under the Privacy Rule, so they are impermissible disclosures rather than gaps in documentation.

164.504 Organizational requirements: BAs, hybrid entities, and organized arrangements**WHAT THE PROVISION REQUIRES**

This section sets out the organizational structures the Privacy Rule recognizes and their requirements. It specifies the required content of business associate contracts, including permitted uses, safeguards, reporting, subcontractor flow-down, individual rights support, availability to the Secretary, return or destruction at termination, and termination for material breach. It also governs health care components of hybrid entities, affiliated covered entities, organized health care arrangements, and the conditions under which a group health plan may disclose PHI to a plan sponsor, including the required plan document amendments and certification.

WHY IT EXISTS

The organizational structures determine how PHI may flow within and between related entities, and choosing one carries obligations. An organized health care arrangement permits joint activities that would otherwise require agreements; a hybrid entity designation limits the Rule to designated components but requires firewalling between them. Structures claimed without their conditions being met provide no protection.

HOW TO AUDIT IT

1. Verify business associate contract content against the required terms, including return or destruction at termination.
2. Where a hybrid entity designation exists, test whether PHI flows between health care and non-health care components are controlled.
3. Check organized health care arrangement or affiliated covered entity designations are documented and conditions met.
4. For group health plans, verify plan document amendments and the sponsor certification exist.

EVIDENCE TO COLLECT

- BA contract terms mapped to requirements
- Hybrid entity component designations and firewalls
- OHCA and ACE designations
- Plan document amendments and certifications

HOW TO DOCUMENT IT

Test hybrid entity firewalls by examining actual access between components, since the designation limits the Rule's scope only if the separation is real.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the hybrid entity designation is documented but PHI flows freely between designated health care components and other parts of the organization, so the separation on which the designation depends does not exist.

164.506 Treatment, payment, and health care operations**WHAT THE PROVISION REQUIRES**

A covered entity may use or disclose PHI for its own treatment, payment, or health care operations without authorization. It may disclose PHI for the treatment activities of another covered entity or provider, for the payment activities of another covered entity or provider, and for the health care operations of another covered entity where both have or had a relationship with the individual, the PHI pertains to that relationship, and the disclosure is for specified operations purposes or for health care fraud and abuse detection. Consent for TPO uses is optional and, if obtained, is at the entity's discretion.

WHY IT EXISTS

TPO is the permission that makes ordinary health care function, and its breadth means most day to day uses require no authorization at all. The boundaries are where problems arise: health care operations is a defined term with an enumerated list, and activities such as marketing and fundraising fall outside it and have their own requirements. Disclosure for another entity's operations is narrower than for treatment and requires the relationship conditions to be met.

HOW TO AUDIT IT

1. Test whether activities characterised as health care operations fall within the defined term.
2. Examine disclosures for another entity's health care operations against the relationship conditions.
3. Check that marketing and fundraising are not being treated as operations.
4. Verify minimum necessary is applied to payment and operations uses, since the exception covers treatment only.

EVIDENCE TO COLLECT

- Activity characterisation against the operations definition
- Relationship evidence for third-party operations disclosures
- Minimum necessary application to payment and operations

HOW TO DOCUMENT IT

Record activities treated as health care operations that fall outside the definition, since these are proceeding without the authorization they actually require.

EXECUTIVE SUMMARY TREATMENT

Suggested language: activities constituting marketing under the Rule are characterised as health care operations and conducted without authorization, so PHI is used for purposes requiring individual permission that was never obtained.

164.508 Uses and disclosures for which an authorization is required**WHAT THE PROVISION REQUIRES**

Except as otherwise permitted, a covered entity may not use or disclose PHI without a valid authorization. A valid authorization must contain a specific and meaningful description of the information, the persons authorized to make and receive the disclosure, a description of each purpose, an expiration date or event, the individual's signature and date, statements regarding the right to revoke, the ability or inability to condition treatment or payment, and the potential for redisclosure. Authorization is required for most uses of psychotherapy notes, for marketing, and for any disclosure constituting a sale of PHI. An authorization is defective if it has expired, is incomplete, has been revoked, or contains material information known to be false, and compound authorizations are restricted.

WHY IT EXISTS

Authorization is the mechanism for uses beyond the Rule's permissions, and its formal requirements are strict: an authorization missing a required element is invalid, which makes the disclosure made in reliance on it impermissible. Marketing and sale of PHI are the categories that most often proceed without recognizing that authorization is required.

HOW TO AUDIT IT

1. Test sampled authorizations against each required element.
2. Verify authorizations are not conditioned on treatment or payment except where permitted.
3. Check whether any activity constitutes marketing or sale of PHI and whether authorization was obtained.
4. Examine psychotherapy notes handling, which requires separate authorization for most uses.

EVIDENCE TO COLLECT

- Sampled authorizations checked element by element
- Marketing and sale determinations
- Psychotherapy notes handling procedures
- Revocation handling

HOW TO DOCUMENT IT

Check authorizations element by element rather than confirming a signed form exists, since a missing required element renders the authorization invalid and the resulting disclosure impermissible.

EXECUTIVE SUMMARY TREATMENT

Suggested language: authorization forms omit required elements including the expiration date and the redisclosure statement, so disclosures made in reliance on them are impermissible.

164.510 Uses and disclosures requiring an opportunity to agree or object

WHAT THE PROVISION REQUIRES

A covered entity may use or disclose PHI in two circumstances if the individual is informed in advance and has the opportunity to agree, prohibit, or restrict. For facility directories, the entity may maintain and disclose the individual's name, location, general condition, and religious affiliation to clergy and, other than religious affiliation, to persons who ask for the individual by name. For persons involved in care and for notification purposes, the entity may disclose PHI directly relevant to a family member, relative, close personal friend, or other person identified by the individual, and may use or disclose to notify or assist in notification about location, general condition, or death. Where the individual is not present or is incapacitated, the entity may exercise professional judgment about whether disclosure is in their best interests.

WHY IT EXISTS

These provisions govern the disclosures most visible to patients and families, and they carry a genuine agree-or-object step that is frequently skipped in practice. The professional judgment route for incapacitated individuals is real but is a judgment about the individual's best interests, not a general permission to disclose to whoever appears to be family.

HOW TO AUDIT IT

1. Verify individuals are informed and given the opportunity to agree or object, with the outcome recorded.
2. Check facility directory practices reflect individual choices, including opt-outs.
3. Examine disclosures to family and friends for whether they are limited to information directly relevant to involvement in care.
4. Test how professional judgment determinations are made and documented for incapacitated individuals.

EVIDENCE TO COLLECT

- Directory opt-out records and their operational effect
- Agree-or-object process evidence
- Disclosure records to involved persons

HOW TO DOCUMENT IT

Test whether a recorded directory opt-out actually prevents disclosure, since the choice is often captured at registration and not enforced at the point staff answer enquiries.

EXECUTIVE SUMMARY TREATMENT

Suggested language: directory opt-out preferences are recorded at registration but are not visible to staff responding to enquiries, so patients who objected to directory inclusion are nonetheless disclosed.

164.512 Disclosures not requiring authorization or an opportunity to object**WHAT THE PROVISION REQUIRES**

A covered entity may use or disclose PHI without authorization or an opportunity to agree or object in twelve enumerated circumstances, each with its own conditions: as required by law; for public health activities; about victims of abuse, neglect, or domestic violence; for health oversight activities; for judicial and administrative proceedings; for law enforcement purposes; about decedents to coroners, medical examiners, and funeral directors; for cadaveric organ, eye, or tissue donation; for research subject to IRB or privacy board approval or other conditions; to avert a serious threat to health or safety; for specialized government functions; and for workers' compensation.

WHY IT EXISTS

These permissions are narrow and condition-laden, and each has specific requirements that must be satisfied for the disclosure to be permissible. The law enforcement and judicial proceedings categories are where errors concentrate, because staff face immediate pressure from an authority figure and the conditions differ substantially depending on the type of request and legal process presented.

HOW TO AUDIT IT

1. For sampled disclosures under this section, identify the specific paragraph relied upon and verify its conditions were met.
2. Examine law enforcement disclosures closely, checking the type of legal process against what the paragraph requires.
3. Verify research disclosures have IRB or privacy board approval or meet an alternative condition.
4. Check that serious threat disclosures meet the good faith and credible threat conditions.

EVIDENCE TO COLLECT

- Disclosure records with paragraph relied upon
- Legal process documentation for law enforcement disclosures
- IRB or privacy board approvals for research
- Accounting entries for these disclosures

HOW TO DOCUMENT IT

Verify the specific conditions of the paragraph relied upon rather than accepting the category, since these disclosures are also accountable under 164.528 and an unconditioned disclosure is both impermissible and unaccounted.

EXECUTIVE SUMMARY TREATMENT

Suggested language: disclosures to law enforcement were made on verbal request without the legal process the relied-upon provision requires, and were not recorded for accounting purposes.

164.514(d)-(h) Minimum necessary implementation and other requirements**WHAT THE PROVISION REQUIRES**

This section contains the implementation requirements for minimum necessary and several related obligations. The entity must identify workforce persons or classes needing access and the categories of PHI required, implement policies limiting routine and recurring disclosures and requests to the minimum necessary, and review non-routine requests individually against criteria. It also governs the limited data set and the data use agreement required for it, uses and disclosures for fundraising and marketing communications, verification of the identity and authority of persons requesting disclosure, and the conditions for disclosures to persons involved in care.

WHY IT EXISTS

The verification requirement is operationally significant and frequently weak: before disclosing PHI to a person the entity does not know, it must verify their identity and their authority to receive it. Social engineering against health care organizations exploits exactly this, and telephone disclosure processes are where verification is most often perfunctory.

HOW TO AUDIT IT

1. Verify identity and authority verification procedures exist and are followed, particularly for telephone requests.
2. Test minimum necessary implementation for routine disclosures and individual review for non-routine requests.
3. Where a limited data set is used, verify a compliant data use agreement is in place.
4. Check fundraising communications include the required opt-out and that opt-outs are honoured.

EVIDENCE TO COLLECT

- Verification procedures and evidence of application
- Minimum necessary policies for routine disclosures
- Data use agreements for limited data sets
- Fundraising opt-out mechanism and records

HOW TO DOCUMENT IT

Test telephone verification practice directly where possible, since this is the most exploited disclosure channel and the procedures are commonly informal.

EXECUTIVE SUMMARY TREATMENT

Suggested language: telephone requests for PHI are fulfilled without documented verification of the caller's identity or authority, leaving the organization's most heavily used disclosure channel open to social engineering.

Privacy Rule: Individual Rights and Administration

Six entries covering 45 CFR 164.520 through 164.530. Blue throughout.

164.524 right of access has been the subject of a sustained enforcement initiative, and the two recurring failures are timeliness and fees. Break the fee schedule into its components and identify any that the Rule does not permit: search and retrieval time is specifically excluded, so per-page schedules and retrieval charges frequently exceed what is allowed. This is concrete, provable, and has been penalised repeatedly. Two rights are structurally under-supported almost everywhere. The mandatory out-of-pocket restriction under 164.522 is one the entity cannot refuse, and systems are rarely configured to honour it. And 164.528 accounting of disclosures is a direct test of whether public interest disclosures are being recorded at the point they are made: an entity that discloses to law enforcement without logging it cannot produce a compliant accounting, and the two failures are the same failure. 164.530 carries the active obligations, sanctions and mitigation, which are commonly documented as policies with no recorded instance of application.

Quick reference: Individual Rights

Navigation: every reference and title below links to its full entry. Links shown in [orange](#) with a **CYB** or **AI** marker denote controls whose subject matter is specifically cybersecurity (CYB) or that are direct attachment points for AI system governance (AI). All others are [blue](#).

Ref	Title	Primary evidence
164.520	Notice of privacy practices	Notice of privacy practices with element check
164.522	Right to request privacy protection for PHI	Restriction request records and outcomes
164.524	Right of access	Access request log with dates
164.526	Right to amend	Amendment request records and outcomes
164.528	Right to an accounting of disclosures	Accounting log with required elements
164.530	Administrative requirements of the Privacy Rule	Privacy official and contact designations

164.520 Notice of privacy practices**WHAT THE PROVISION REQUIRES**

An individual has a right to adequate notice of the uses and disclosures of PHI that may be made, the individual's rights, and the covered entity's legal duties. The notice must be written in plain language and contain specified content including a header in the prescribed terms, descriptions of uses and disclosures with examples, statements about uses requiring authorization, a description of individual rights, the entity's duties, complaint procedures, a contact point, and the effective date. A provider with a direct treatment relationship must provide the notice no later than the date of first service delivery, make a good faith effort to obtain written acknowledgment of receipt, and document any failure to obtain it. The notice must be posted and made available, including on any website.

WHY IT EXISTS

The notice is the primary transparency mechanism and its requirements are prescriptive, including the header wording. The acknowledgment requirement is separate from provision: providers must attempt to obtain written acknowledgment and must document the attempt where it fails, and the documentation of failed attempts is routinely absent.

HOW TO AUDIT IT

1. Check notice content against each required element, including the prescribed header.
2. Verify the notice is provided by first service delivery and is posted and available on any website.
3. Test acknowledgment records and, where acknowledgment was not obtained, whether the good faith effort and its failure are documented.
4. Confirm the notice reflects actual practice, including any material revisions.

EVIDENCE TO COLLECT

- Notice of privacy practices with element check
- Provision and posting evidence
- Acknowledgment records and documented failures

HOW TO DOCUMENT IT

Record whether failures to obtain acknowledgment are documented, since the obligation is to document the good faith effort and its outcome, not merely to collect signatures where they are given.

EXECUTIVE SUMMARY TREATMENT

Suggested language: written acknowledgment of the notice is obtained for only a stated proportion of patients, and no documentation exists of the good faith efforts made where acknowledgment was not obtained.

164.522 Right to request privacy protection for PHI**WHAT THE PROVISION REQUIRES**

An individual has the right to request restriction of uses and disclosures for treatment, payment, or health care operations and of disclosures to persons involved in care. The covered entity is not generally required to agree, but if it does agree it is bound by the restriction except for emergency treatment. The entity must agree to a request to restrict disclosure to a health plan where the disclosure is for payment or operations, is not otherwise required by law, and the PHI pertains solely to an item or service for which the individual or another person has paid out of pocket in full. The individual also has the right to request and receive communications by alternative means or at alternative locations, which providers must accommodate for reasonable requests without requiring a reason.

WHY IT EXISTS

The out-of-pocket restriction is mandatory rather than discretionary and is frequently unknown to front-line staff, so requests are refused that the entity is obliged to grant. Confidential communications requests must be accommodated by providers where reasonable and without asking why, which is a lower bar than staff often apply.

HOW TO AUDIT IT

1. Verify staff and systems can recognise and honour a mandatory out-of-pocket restriction request.
2. Check agreed restrictions are technically enforced rather than recorded and forgotten.
3. Test confidential communications requests, confirming providers accommodate reasonable requests without requiring a reason.
4. Examine refusals of restriction requests for whether any fell within the mandatory category.

EVIDENCE TO COLLECT

- Restriction request records and outcomes
- Enforcement mechanism for agreed restrictions
- Confidential communications accommodations

HOW TO DOCUMENT IT

Record whether the mandatory out-of-pocket restriction is recognised and operationally supported, since this is the one restriction the entity cannot refuse and the one systems are least often configured for.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the organization has no mechanism to restrict disclosure to a health plan where an individual has paid out of pocket in full, so it cannot honour a restriction the Rule makes mandatory.

164.524 Right of access

WHAT THE PROVISION REQUIRES

An individual has a right of access to inspect and obtain a copy of PHI about them in a designated record set, for as long as it is maintained, with narrow exceptions including psychotherapy notes and information compiled for legal proceedings. The entity must act on a request within 30 days, with one 30-day extension permitted on written notice stating the reason and the expected date. Access must be provided in the form and format requested if readily producible, including electronic copies of electronic records, and the entity must transmit the copy to a designated third party if directed in a signed written request. Fees must be reasonable and cost-based and may include only labour for copying, supplies, postage, and preparing a summary if agreed.

WHY IT EXISTS

Right of access has been the subject of a sustained enforcement initiative, and the two failures that recur are timeliness and fees. The permitted fee components are narrow and specifically exclude search and retrieval time, so fee schedules built on per-page rates or including retrieval costs frequently exceed what the Rule allows.

HOW TO AUDIT IT

1. Measure elapsed time from request to fulfilment across a sample, and check extensions were notified in writing with reasons.
2. Test the fee schedule against the permitted components, since search and retrieval time is not chargeable.
3. Verify electronic copies are provided where records are electronic and the individual requests that form.
4. Check third-party transmission requests are honoured.

EVIDENCE TO COLLECT

- Access request log with dates
- Fee schedule with component breakdown
- Form and format fulfilment evidence
- Extension notifications

HOW TO DOCUMENT IT

Break the fee schedule into components and identify any that are not permitted, since this is concrete, provable, and has been a consistent enforcement focus.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the access fee schedule includes search and retrieval costs that the Rule does not permit, and a stated proportion of requests exceeded 30 days with no written extension notice.

164.526 Right to amend**WHAT THE PROVISION REQUIRES**

An individual has the right to have a covered entity amend PHI in a designated record set for as long as it is maintained. The entity may deny the request where it did not create the information, the information is not part of the designated record set, it would not be available for inspection, or it is accurate and complete. The entity must act within 60 days with one 30-day extension. If it accepts, it must make the amendment, inform the individual, and make reasonable efforts to notify persons identified by the individual and those known to have the PHI who may rely on it. If it denies, it must provide a written denial in plain language with the basis, the right to submit a statement of disagreement, and complaint procedures.

WHY IT EXISTS

Amendment does not mean deletion: the record is amended by addition, preserving the original entry, which is essential for clinical and legal integrity. The statement of disagreement is a genuine right where a request is denied, and entities frequently deny requests without the required written explanation or without informing the individual of that right.

HOW TO AUDIT IT

1. Verify amendment requests are acted on within 60 days with extensions properly notified.
2. Check denials are written, in plain language, state the basis, and explain the statement of disagreement right.
3. Verify accepted amendments are propagated to persons known to hold and rely on the PHI.
4. Confirm statements of disagreement are recorded and included in future disclosures.

EVIDENCE TO COLLECT

- Amendment request records and outcomes
- Denial letters with required content
- Propagation evidence for accepted amendments
- Statements of disagreement and their inclusion

HOW TO DOCUMENT IT

Check denial letters against the required content, since a denial that omits the statement of disagreement right deprives the individual of the remedy the Rule provides for exactly that situation.

EXECUTIVE SUMMARY TREATMENT

Suggested language: amendment requests are denied without written explanation of the basis or notice of the right to submit a statement of disagreement, so individuals are given no route to record their disagreement in the record.

164.528 Right to an accounting of disclosures**WHAT THE PROVISION REQUIRES**

An individual has the right to receive an accounting of disclosures of PHI made by a covered entity in the six years prior to the request, excluding disclosures for treatment, payment and health care operations, to the individual, incident to permitted uses, pursuant to authorization, for facility directories and persons involved in care, for national security or intelligence, to correctional institutions, and as part of a limited data set. The accounting must include the date, the recipient's name and address if known, a brief description of the PHI, and a brief statement of the purpose. The entity must act within 60 days with one 30-day extension, and must provide the first accounting in any twelve-month period without charge.

WHY IT EXISTS

The exclusions are extensive, so the accountable population is dominated by the 164.512 public interest disclosures. This makes the accounting obligation a direct test of whether those disclosures are being recorded at all: an entity that discloses to law enforcement or public health without logging it cannot produce a compliant accounting, and the two failures are the same failure.

HOW TO AUDIT IT

1. Verify a mechanism exists to record accountable disclosures at the point they are made.
2. Test whether a sampled 164.512 disclosure appears in the accounting record.
3. Check accounting responses are provided within 60 days and include all required elements.
4. Confirm the first accounting in a twelve-month period is provided without charge.

EVIDENCE TO COLLECT

- Accounting log with required elements
- Sampled 164.512 disclosures traced to the log
- Accounting responses with dates

HOW TO DOCUMENT IT

Trace specific public interest disclosures into the accounting log, since the absence of a recording mechanism means the accounting produced is incomplete regardless of how promptly it is delivered.

EXECUTIVE SUMMARY TREATMENT

Suggested language: accountable disclosures are not recorded at the point of disclosure, so any accounting provided to an individual is materially incomplete and the organization cannot meet the right.

164.530 Administrative requirements of the Privacy Rule**WHAT THE PROVISION REQUIRES**

A covered entity must designate a privacy official responsible for developing and implementing policies and procedures, and a contact person for complaints. It must train all workforce members on policies and procedures as necessary and appropriate for their functions, by the compliance date and for new members within a reasonable period, and when policies materially change. It must have appropriate administrative, technical, and physical safeguards to protect privacy, provide a complaints process, apply sanctions against workforce members who violate policies, mitigate known harmful effects of impermissible uses or disclosures, refrain from intimidating or retaliatory acts, not require waiver of rights as a condition of treatment or payment, maintain policies and procedures in writing, and retain documentation for six years.

WHY IT EXISTS

This section is the Privacy Rule's counterpart to the Security Rule's administrative safeguards and contains several obligations that are separately actionable. The mitigation duty is the one most often overlooked: on learning of an impermissible use or disclosure, the entity must mitigate known harmful effects to the extent practicable, which is an active obligation beyond investigating and recording.

HOW TO AUDIT IT

1. Verify a privacy official and complaints contact are designated and current.
2. Reconcile privacy training completion against the full workforce, including for material policy changes.
3. Check the sanction policy has been applied where violations occurred, since consistent non-application undermines it.
4. Examine whether mitigation was undertaken following known impermissible disclosures.

EVIDENCE TO COLLECT

- Privacy official and contact designations
- Training records against full workforce
- Complaint records and outcomes
- Sanction and mitigation records

HOW TO DOCUMENT IT

Record whether sanctions have actually been applied and whether mitigation followed known impermissible disclosures, since both are active obligations and both are commonly documented as policies with no instances of application.

EXECUTIVE SUMMARY TREATMENT

Suggested language: impermissible disclosures identified during the period resulted in no sanctions and no documented mitigation of harmful effects, so two active obligations under the Privacy Rule were not discharged.

CHAPTER 8

Breach Notification Rule

Six entries covering 45 CFR 164.400 through 164.414. Blue throughout.

Two features govern everything in this chapter. First, the presumption: an impermissible use or disclosure IS a breach unless the entity demonstrates through a four-factor risk assessment that there is a low probability the PHI was compromised. Inaction therefore produces a notifiable breach by default, and an assessment that reasons generally about harm without addressing all four factors has not rebutted anything. Second, the burden of proof under 164.414(b) sits with the entity: it must demonstrate either that it notified or that no breach occurred.

Those two combine into the single most useful test in this chapter. For each sampled incident, ask whether the documentation would discharge the burden. Gaps are conclusive against the entity rather than merely unhelpful.

On timing, discovery is constructive: the clock starts when the entity knew or by reasonable diligence would have known, including through any workforce member, not when the investigation concludes or management is briefed. Establish that date independently. And the under-500 annual submission under 164.408 is the obligation most often missed entirely, because it requires a log maintained across the year and a filing after year end.

Quick reference: Breach Notification

Navigation: every reference and title below links to its full entry. Links shown in orange with a **CYB** or **AI** marker denote controls whose subject matter is specifically cybersecurity (CYB) or that are direct attachment points for AI system governance (AI). All others are blue.

Ref	Title	Primary evidence
164.402	Definition of breach and the risk assessment	Risk assessments with all four factors documented
164.404	Notification to individuals	Breach log with discovery and notification dates
164.406	Notification to the media	Affected individual counts by State
164.408	Notification to the Secretary	Secretary notifications for large breaches
164.410	Notification by a business associate	Agreement reporting timeframes
164.412-414	Law enforcement delay, administrative requirements, and burden of proof	Breach policies and training records

164.402 Definition of breach and the risk assessment

WHAT THE PROVISION REQUIRES

A breach is the acquisition, access, use, or disclosure of protected health information in a manner not permitted by the Privacy Rule which compromises the security or privacy of the PHI. Three exceptions apply: unintentional acquisition, access, or use by a workforce member acting in good faith within the scope of authority, where it does not result in further impermissible use or disclosure; inadvertent disclosure between authorized persons at the same entity, organized health care arrangement, or business associate, again where there is no further impermissible use or disclosure; and disclosure where the entity has a good faith belief the unauthorized recipient would not reasonably have been able to retain the information. An impermissible use or disclosure is presumed to be a breach unless the entity demonstrates through a risk assessment that there is a low probability the PHI has been compromised, assessing at least four factors: the nature and extent of the PHI including identifiers and likelihood of re-identification, the unauthorized person who used it or to whom it was disclosed, whether the PHI was actually acquired or viewed, and the extent to which the risk has been mitigated.

WHY IT EXISTS

The presumption is the operative feature: an impermissible use or disclosure is a breach unless the entity affirmatively demonstrates low probability of compromise, so the burden sits with the entity and inaction produces a notifiable breach by default. All four factors must be assessed, and risk assessments that consider only whether harm is likely, or that skip factors, do not rebut the presumption.

HOW TO AUDIT IT

1. Verify a risk assessment is performed for every impermissible use or disclosure, not only those that appear serious.
2. Check all four factors are assessed and documented in each assessment.
3. Test whether the exceptions are applied correctly and not stretched beyond their conditions.
4. Examine incidents concluded as non-breaches for whether the presumption was actually rebutted.

EVIDENCE TO COLLECT

- Risk assessments with all four factors documented
- Incidents assessed as non-breaches with reasoning
- Exception determinations

HOW TO DOCUMENT IT

Record whether the four factors are each addressed, since an assessment that reasons generally about harm has not rebutted the presumption and the incident remains a notifiable breach.

EXECUTIVE SUMMARY TREATMENT

Suggested language: risk assessments for impermissible disclosures do not address the four required factors, so the presumption that each incident was a breach has not been rebutted and the incidents should have been notified.

164.404 Notification to individuals

WHAT THE PROVISION REQUIRES

Following discovery of a breach of unsecured PHI, a covered entity must notify each individual whose information has been, or is reasonably believed to have been, accessed, acquired, used, or disclosed. Notification must be without unreasonable delay and in no case later than 60 calendar days after discovery. A breach is treated as discovered on the first day it is known, or by exercising reasonable diligence would have been known, to the entity, including to any person other than the individual committing the breach who is a workforce member or agent. The notice must be in plain language and include a brief description of what happened and the dates, the types of information involved, steps individuals should take to protect themselves, what the entity is doing to investigate, mitigate, and protect against further breaches, and contact procedures. Notice is by first-class mail or by email if the individual has agreed, with substitute notice where contact information is insufficient or out of date.

WHY IT EXISTS

Discovery is defined constructively: the clock starts when the entity knew or by exercising reasonable diligence would have known, not when the investigation concludes or when management is briefed. The 60-day period is an outer limit rather than a target, since the standard is without unreasonable delay, and an entity that takes the full 60 days without justification may still have delayed unreasonably.

HOW TO AUDIT IT

1. Establish the actual discovery date independently, applying the constructive knowledge standard.
2. Measure elapsed time from discovery to notification and assess whether any delay was reasonable.
3. Check notice content against each required element.
4. Verify substitute notice was used where contact information was insufficient, and met its requirements.

EVIDENCE TO COLLECT

- Breach log with discovery and notification dates
- Notification letters with content check
- Substitute notice evidence
- Basis for discovery date determination

HOW TO DOCUMENT IT

Determine the discovery date from the point any workforce member knew or should have known, not from formal declaration, since the gap between the two is where the 60 days is consumed.

EXECUTIVE SUMMARY TREATMENT

Suggested language: notification was issued a stated number of days after workforce members first became aware of the incident, exceeding the 60-day limit measured from constructive discovery rather than from formal declaration.

164.406 Notification to the media

WHAT THE PROVISION REQUIRES

For a breach of unsecured PHI involving more than 500 residents of a State or jurisdiction, a covered entity must notify prominent media outlets serving that State or jurisdiction, without unreasonable delay and in no case later than 60 calendar days after discovery. The content requirements are the same as for individual notification.

WHY IT EXISTS

The threshold is counted per State or jurisdiction rather than in total, so a breach affecting a large number nationally may trigger media notification in some States and not others, and conversely a geographically concentrated breach can cross the threshold at a lower total. The counting is frequently done in aggregate, which produces the wrong answer in both directions.

HOW TO AUDIT IT

1. Verify affected individual counts are determined per State or jurisdiction rather than only in total.
2. Check media notification was made where the threshold was crossed in any jurisdiction.
3. Confirm notification timing against the 60-day limit.
4. Examine content against the individual notification requirements.

EVIDENCE TO COLLECT

- Affected individual counts by State
- Media notification evidence and timing

HOW TO DOCUMENT IT

Record how affected counts were allocated by State, since aggregate counting is the common error and it determines whether this obligation was triggered at all.

EXECUTIVE SUMMARY TREATMENT

Suggested language: affected individuals were counted only in aggregate, so media notification obligations triggered in a stated number of States were not identified or met.

164.408 Notification to the Secretary

WHAT THE PROVISION REQUIRES

A covered entity must notify the Secretary of breaches of unsecured PHI. For breaches involving 500 or more individuals, notification must be contemporaneous with individual notice and in the manner specified on the HHS website. For breaches involving fewer than 500 individuals, the entity must maintain a log or other documentation and submit notification for all such breaches occurring during a calendar year no later than 60 days after the end of that year.

WHY IT EXISTS

The under-500 annual reporting obligation is the one most often missed, because it requires a log of small breaches maintained across the year and a submission after year end. Entities that handle individual notifications correctly frequently fail to make the annual submission, and the log itself is often absent, which makes the omission both a reporting failure and a documentation failure.

HOW TO AUDIT IT

1. Verify large breaches were reported to the Secretary contemporaneously with individual notice.
2. Check a log of under-500 breaches is maintained through the year.
3. Confirm the annual submission was made within 60 days of year end and covered all logged breaches.
4. Reconcile the log against the incident record for completeness.

EVIDENCE TO COLLECT

- Secretary notifications for large breaches
- Annual log of small breaches
- Annual submission evidence with date
- Incident records for reconciliation

HOW TO DOCUMENT IT

Reconcile the small-breach log against the incident and risk assessment records, since incidents assessed as breaches but omitted from the log will not have been reported at all.

EXECUTIVE SUMMARY TREATMENT

Suggested language: no annual submission of breaches affecting fewer than 500 individuals has been made to the Secretary, and no log of such breaches is maintained, despite a stated number of qualifying incidents during the period.

164.410 Notification by a business associate**WHAT THE PROVISION REQUIRES**

Following discovery of a breach of unsecured PHI, a business associate must notify the covered entity without unreasonable delay and in no case later than 60 calendar days after discovery. A breach is treated as discovered on the first day it is known, or by exercising reasonable diligence would have been known, to the business associate, including any person other than the one committing the breach who is an employee, officer, or agent. The notification must include, to the extent possible, the identification of each individual affected and any other information the covered entity is required to include in its notification to individuals.

WHY IT EXISTS

The business associate's 60 days runs from its own discovery, and the covered entity's 60 days runs from when it is deemed to have discovered the breach, which creates a serious timing problem: a business associate that uses its full 60 days may leave the covered entity with no time at all. This is why agreements should specify a materially shorter reporting period than the regulatory maximum.

HOW TO AUDIT IT

1. Check business associate agreements specify a reporting period short enough to allow the covered entity to meet its own deadline.
2. Verify business associate breach notifications received include the required content.
3. Examine whether the covered entity has any means of learning about business associate breaches independently.
4. Test timing on any actual business associate breach.

EVIDENCE TO COLLECT

- Agreement reporting timeframes
- Business associate breach notifications received
- Covered entity response timing

HOW TO DOCUMENT IT

Record the reporting timeframe specified in agreements against the covered entity's own deadline, since a 60-day contractual period leaves the covered entity structurally unable to comply.

EXECUTIVE SUMMARY TREATMENT

Suggested language: business associate agreements permit the regulatory maximum of 60 days for breach reporting, which leaves the organization no time to conduct its own assessment and notify individuals within its deadline.

164.412-414 Law enforcement delay, administrative requirements, and burden of proof**WHAT THE PROVISION REQUIRES**

If a law enforcement official states that notification would impede a criminal investigation or cause damage to national security, the entity must delay notification for the time specified if the statement is in writing, or, if made orally, document the statement and delay no longer than 30 days unless a written statement is submitted. The administrative requirements of 164.530 relating to policies and procedures, training, complaints, sanctions, refraining from retaliation, and documentation apply to the Breach Notification Rule. In the event of an impermissible use or disclosure, the covered entity or business associate has the burden of demonstrating that all required notifications were made or that the use or disclosure did not constitute a breach.

WHY IT EXISTS

The burden of proof provision is what makes documentation decisive: the entity must demonstrate either that it notified or that no breach occurred, so an incident with no documented risk assessment and no notification is a failure by default. The law enforcement delay is real but is bounded and conditional, and an oral statement supports only a 30-day delay unless followed in writing.

HOW TO AUDIT IT

1. Verify breach policies, procedures, and training exist as the administrative requirements demand.
2. Check any law enforcement delay is supported by a written statement, or by documentation of an oral one within the 30-day limit.
3. Test whether the entity could demonstrate, for each incident, that it notified or that no breach occurred.
4. Examine documentation retention for breach records across the six-year period.

EVIDENCE TO COLLECT

- Breach policies and training records
- Law enforcement delay statements and documentation
- Complete incident documentation demonstrating compliance

HOW TO DOCUMENT IT

For each sampled incident, test whether the documentation would discharge the burden of proof, since this is the standard the entity would face and gaps in it are conclusive against the entity rather than merely unhelpful.

EXECUTIVE SUMMARY TREATMENT

Suggested language: incident documentation would not discharge the organization's burden of demonstrating either that notification occurred or that no breach took place, so unresolved incidents would be treated as unnotified breaches.

Enforcement, Culpability, and Penalties

Three entries covering 45 CFR Part 160 Subpart D. Blue throughout.

HIPAA penalties key off culpability rather than off which provision was breached, which is why this guide does not colour entries by penalty tier the way the companion GDPR guide does. The four categories run from did-not-know through reasonable cause to wilful neglect corrected and wilful neglect uncorrected, and the same underlying failure can sit in any of them depending on what the entity knew and did.

That has a direct consequence for how findings should be written. A deficiency the organization already knew about and left open is materially worse than an undiscovered one, because knowledge converts the culpability category. A risk analysis that identifies a gap the entity then fails to close is the clearest route from a low tier to wilful neglect. Identify those deficiencies explicitly and say so.

The 30-day correction window under 160.410 is a complete defense for violations not due to wilful neglect, so measure the organization's actual time from discovery to correction. A remediation process running on annual cycles forfeits a defense that would otherwise be available.

Quick reference: Enforcement

Navigation: every reference and title below links to its full entry. Links shown in **orange** with a **CYB** or **AI** marker denote controls whose subject matter is specifically cybersecurity (CYB) or that are direct attachment points for AI system governance (AI). All others are **blue**.

Ref	Title	Primary evidence
160.401-402	Basis for a civil money penalty and culpability categories	Prior assessment and audit findings with remediation status
160.404-408	Penalty amounts and the factors considered	Deficiency duration evidence
160.410	Affirmative defenses and the correction opportunity	Remediation process and typical timescales

160.401-402 Basis for a civil money penalty and culpability categories

WHAT THE PROVISION REQUIRES

The Secretary will impose a civil money penalty on a covered entity or business associate that violates an administrative simplification provision. Liability turns on culpability, defined across four categories: the entity did not know and by exercising reasonable diligence would not have known of the violation; the violation was due to reasonable cause and not wilful neglect; the violation was due to wilful neglect and was corrected within 30 days of when the entity knew or should have known; and the violation was due to wilful neglect and was not corrected within that period. Reasonable cause means an act or omission in which a covered entity or business associate knew, or by exercising reasonable diligence would have known, that an act or omission violated a provision, but did not act with wilful neglect. Wilful neglect means conscious, intentional failure or reckless indifference to the obligation to comply.

WHY IT EXISTS

Culpability drives penalty exposure far more than the technical nature of the violation, which means the same underlying failure can attract very different consequences depending on what the entity knew and did. This is why an unaddressed known deficiency is materially worse than an undiscovered one, and why a risk analysis that identifies a gap the entity then leaves open converts a lower-tier position into wilful neglect.

HOW TO AUDIT IT

1. Assess where identified deficiencies would place the organization on the culpability scale.
2. Examine known but unremediated findings, since these are the ones that establish knowledge.
3. Check whether prior assessments, audits, or incidents put the organization on notice of the deficiency.
4. Verify correction processes can operate within 30 days of knowledge where required.

EVIDENCE TO COLLECT

- Prior assessment and audit findings with remediation status
- Incident records establishing knowledge
- Remediation timelines

HOW TO DOCUMENT IT

Identify deficiencies the organization already knew about and has not corrected, and state this explicitly, since knowledge converts the culpability category and is the single most consequential factor in penalty exposure.

EXECUTIVE SUMMARY TREATMENT

Suggested language: a stated number of deficiencies identified in prior assessments remain unremediated, which establishes organizational knowledge and would likely place any resulting violation in the wilful neglect category rather than the lowest culpability tier.

160.404-408 Penalty amounts and the factors considered**WHAT THE PROVISION REQUIRES**

Penalty amounts are set by culpability category, with a minimum and maximum per violation in each and an annual cap for identical violations, and the amounts are subject to annual inflation adjustment. In determining the amount, the Secretary considers the nature and extent of the violation including the number of individuals affected and duration, the nature and extent of the resulting harm including physical, financial, and reputational harm and whether it hindered an individual's ability to obtain health care, the entity's history of prior compliance including whether the current violation is the same or similar to previous indications and how previous ones were addressed, the financial condition of the entity, and such other matters as justice may require.

WHY IT EXISTS

The duration factor means an ongoing violation accumulates exposure for as long as it persists, so remediation timing has direct financial consequence. Prior compliance history is also weighed explicitly, which means a recurrence of a previously identified issue is treated more severely than a first occurrence. Both factors reward prompt correction more than they reward avoiding the finding.

HOW TO AUDIT IT

1. Assess the duration of identified deficiencies, since duration is an explicit penalty factor.
2. Check whether current findings repeat previously identified issues.
3. Examine the potential harm to individuals from identified deficiencies, including effects on access to care.
4. Verify remediation of prior findings was effective rather than nominal.

EVIDENCE TO COLLECT

- Deficiency duration evidence
- Prior finding history and recurrence analysis
- Harm analysis for identified deficiencies

HOW TO DOCUMENT IT

State the duration of each significant deficiency and whether it repeats a prior finding, since these two factors convert compliance findings into a concrete statement about exposure.

EXECUTIVE SUMMARY TREATMENT

Suggested language: a stated number of findings repeat deficiencies identified in previous assessments and have persisted for a stated period, both of which are explicit aggravating factors in determining penalty amounts.

160.410 Affirmative defenses and the correction opportunity**WHAT THE PROVISION REQUIRES**

The Secretary may not impose a civil money penalty on a covered entity or business associate for a violation if it is established that the violation is punishable as a criminal offense under the applicable statute. Additionally, for violations not due to wilful neglect, the Secretary may not impose a penalty where the violation is corrected within 30 days of when the entity knew, or by exercising reasonable diligence would have known, that the violation occurred, with the possibility of an extended period as the Secretary determines appropriate. The Secretary may also waive a penalty for violations not due to wilful neglect to the extent payment would be excessive given the nature and extent of the violation.

WHY IT EXISTS

The 30-day correction window is a genuine and complete defense for violations not attributable to wilful neglect, which makes rapid remediation on discovery materially valuable rather than merely good practice. It is also unavailable where wilful neglect applies, so the two provisions interact: an entity that knew of a deficiency and left it loses both the lower culpability tier and the correction defense at the same time.

HOW TO AUDIT IT

1. Assess whether the organization could correct an identified violation within 30 days of discovery.
2. Examine whether remediation processes operate on that timescale or on quarterly or annual cycles.
3. Check that discovery of a deficiency triggers prompt remediation rather than entering a backlog.

EVIDENCE TO COLLECT

- Remediation process and typical timescales
- Time from discovery to correction for past findings

HOW TO DOCUMENT IT

Measure actual time from discovery to correction for past findings, since a remediation process operating on annual cycles forfeits a defense that would otherwise be available.

EXECUTIVE SUMMARY TREATMENT

Suggested language: remediation of identified deficiencies operates on an annual cycle, so the organization systematically forfeits the 30-day correction defense available for violations not due to wilful neglect.

Glossary

Terms are listed alphabetically. Each is also indexed at the point of first use.

Addressable

An implementation specification the entity must assess for whether it is reasonable and appropriate. If it is, implement it. If not, document why and implement an equivalent alternative where reasonable and appropriate. It does NOT mean optional. Neither implementing nor documenting is a violation.

Affiliated covered entity

Legally separate covered entities under common ownership or control that designate themselves as a single covered entity for HIPAA purposes.

Breach

Acquisition, access, use, or disclosure of PHI not permitted by the Privacy Rule which compromises its security or privacy. Presumed unless the entity demonstrates a low probability of compromise through the four-factor risk assessment.

Business associate

A person or entity that creates, receives, maintains, or transmits PHI on behalf of a covered entity to perform a regulated function, or provides specified services involving PHI. Directly liable under the Security Rule and specified Privacy Rule provisions since HITECH and the Omnibus Rule.

Covered entity

A health plan, health care clearinghouse, or health care provider who transmits health information electronically in connection with a covered transaction.

Designated record set

The records used to make decisions about individuals, including medical and billing records. Defines the scope of the access and amendment rights.

Discovery

For breach notification, the first day a breach is known, or by exercising reasonable diligence would have been known, to the entity, including through any workforce member or agent other than the person who committed the breach. Constructive, not actual.

ePHI

Protected health information transmitted by or maintained in electronic media. The Security Rule applies to ePHI only; the Privacy Rule applies to PHI in any form.

Expert Determination

One of the two de-identification methods. A person with appropriate knowledge and experience applies statistical and scientific principles to determine the re-identification risk is very small, and documents the methods and results.

Health care operations

A defined term with an enumerated list, covering activities such as quality assessment, credentialing, and

business management. Marketing and fundraising fall outside it and have their own requirements.

Hybrid entity

A single legal entity performing both covered and non-covered functions that designates its health care components. Without a documented designation, the Rules apply to the whole entity.

Limited data set

PHI with specified direct identifiers removed, usable for research, public health, or operations under a data use agreement. Not de-identified, and still PHI.

Minimum necessary

The standard requiring reasonable efforts to limit use, disclosure, and requests to the minimum needed for the purpose. Does not apply to treatment disclosures to providers, to the individual, under authorization, to the Secretary, or as required by law.

Organized health care arrangement

A clinically integrated care setting or joint arrangement among covered entities permitting certain joint activities without separate agreements.

PHI

Protected health information: individually identifiable health information held or transmitted by a covered entity or business associate, in any form or medium.

Required

An implementation specification that must be implemented as stated. No alternative, no documented-exception route.

Risk analysis

The required assessment under 164.308(a)(1) of potential risks and vulnerabilities to the confidentiality, integrity, and availability of ePHI. The foundation of the Security Rule and the most frequently cited deficiency in enforcement actions.

Safe Harbor

One of the two de-identification methods. Removal of eighteen specified identifier categories relating to the individual, relatives, employers, and household members, plus no actual knowledge that the remainder could identify the individual.

Security incident

Attempted or successful unauthorized access, use, disclosure, modification, or destruction of information, or interference with system operations. Includes attempts, which is broader than most entities operate to. Every breach is a security incident; not every incident is a breach.

Standard

A mandatory Security Rule requirement. Some have implementation specifications beneath them; those that do not are mandatory in themselves.

Unsecured PHI

PHI not rendered unusable, unreadable, or indecipherable to unauthorized persons through a technology or methodology specified by the Secretary. Breach notification obligations attach only to unsecured PHI, which is why encryption matters well beyond the Security Rule.

Wilful neglect

Conscious, intentional failure or reckless indifference to the obligation to comply. The highest culpability category, and the one that removes the 30-day correction defense.

Workforce

Employees, volunteers, trainees, and other persons whose conduct is under the direct control of the entity, whether or not paid. Broader than the employee population, and the difference matters for training completion.

Workpaper

The assessor's record of what was tested, how, what was found, and what was concluded. Written so a reviewer can follow the reasoning without re-performing the work.

Index of Terms and Concepts

- Access control, [24](#)
- Addressable, [59](#)
- Administrative requirements of the Privacy Rule, [47](#)
- Affiliated covered entity, [59](#)
- Affirmative defenses and the correction opportunity, [58](#)
- Assigned security responsibility, [10](#)
- Audit controls, [25](#)

- Basis for a civil money penalty and culpability categories, [56](#)
- Breach, [59](#)
- Business associate, [59](#)
- Business associate contracts and other arrangements, [17](#)
- Business associate contracts or other arrangements, [30](#)
- Business associates and subcontractors, [3](#)

- Contingency plan, [15](#)
- Covered entities: who the Rules apply to directly, [2](#)
- Covered entity, [59](#)

- De-identification: Safe Harbor and Expert Determination, [5](#)
- Definition of breach and the risk assessment, [49](#)
- Designated record set, [59](#)
- Device and media controls, [22](#)
- Disclosures not requiring authorization or an opportunity to object, [39](#)
- Discovery, [59](#)

- ePHI, [59](#)
- Evaluation, [16](#)
- Expert Determination, [59](#)

- Facility access controls, [19](#)

- Health care operations, [59](#)
- Hybrid entity, [60](#)

- Information access management, [12](#)
- Integrity, [26](#)

- Law enforcement delay, administrative requirements, and burden of proof, [54](#)
- Limited data set, [60](#)

- Minimum necessary, [60](#)
- Minimum necessary implementation and other requirements, [40](#)

- Notice of privacy practices, [42](#)
- Notification by a business associate, [53](#)
- Notification to individuals, [50](#)
- Notification to the media, [51](#)
- Notification to the Secretary, [52](#)

- Organizational requirements: BAs, hybrid entities, and organized arrangements, [35](#)
- Organized health care arrangement, [60](#)

- Penalty amounts and the factors considered, [57](#)
- Person or entity authentication, [27](#)
- PHI, [60](#)
- Policies, procedures, and documentation requirements, [32](#)
- Protected health information and its electronic form, [4](#)

- Required, [60](#)
- Required and addressable specifications (45 CFR 164.306), [7](#)
- Requirements for group health plans, [31](#)
- Right of access, [44](#)
- Right to amend, [45](#)
- Right to an accounting of disclosures, [46](#)
- Right to request privacy protection for PHI, [43](#)
- Risk analysis, [60](#)

- Safe Harbor, [60](#)
- Security awareness and training, [13](#)
- Security incident, [60](#)

Security incident procedures, [14](#)
Security management process, [9](#)
Standard, [60](#)

The minimum necessary standard, [6](#)
Transmission security, [28](#)
Treatment, payment, and health care operations,
[36](#)

Unsecured PHI, [60](#)
Uses and disclosures for which an authorization
is required, [37](#)
Uses and disclosures of PHI: general rules, [34](#)
Uses and disclosures requiring an opportunity to
agree or object, [38](#)

Wilful neglect, [60](#)
Workforce, [61](#)
Workforce security, [11](#)
Workpaper, [61](#)
Workstation security, [21](#)
Workstation use, [20](#)